

CIS Microsoft IIS 10 Benchmark

v1.2.1 - 07-17-2023

Terms of Use

Please see the below link for our current terms of use:

<https://www.cisecurity.org/cis-securesuite/cis-securesuite-membership-terms-of-use/>

Table of Contents

Terms of Use	1
Table of Contents	2
Overview	5
Intended Audience.....	5
Consensus Guidance	6
Typographical Conventions.....	7
Recommendation Definitions.....	8
Title.....	8
Assessment Status.....	8
Automated	8
Manual.....	8
Profile	8
Description.....	8
Rationale Statement	8
Impact Statement.....	9
Audit Procedure.....	9
Remediation Procedure.....	9
Default Value.....	9
References	9
CIS Critical Security Controls® (CIS Controls®)	9
Additional Information.....	9
Profile Definitions	10
Acknowledgements	11
Recommendations	12
1 Basic Configurations.....	12
1.1 (L1) Ensure 'Web content' is on non-system partition (Manual)	13
1.2 (L1) Ensure 'Host headers' are on all sites (Automated)	15
1.3 (L1) Ensure 'Directory browsing' is set to Disabled (Automated)	18
1.4 (L1) Ensure 'application pool identity' is configured for all application pools (Automated).....	21
1.5 (L1) Ensure 'unique application pools' is set for sites (Automated)	25
1.6 (L1) Ensure 'application pool identity' is configured for anonymous user identity (Automated)	28
1.7 (L1) Ensure 'WebDav' feature is disabled (Automated).....	31
2 Configure Authentication and Authorization	33
2.1 (L1) Ensure 'global authorization rule' is set to restrict access (Manual).....	34
2.2 (L1) Ensure access to sensitive site features is restricted to authenticated principals only (Manual) ...	38
2.3 (L1) Ensure 'forms authentication' require SSL (Automated)	42

2.4 (L2) Ensure 'forms authentication' is set to use cookies (Automated)	45
2.5 (L1) Ensure 'cookie protection mode' is configured for forms authentication (Automated)	48
2.6 (L1) Ensure transport layer security for 'basic authentication' is configured (Automated)	51
2.7 (L1) Ensure 'passwordFormat' is not set to clear (Automated)	54
2.8 (L2) Ensure 'credentials' are not stored in configuration files (Automated)	57
3 ASP.NET Configuration Recommendations	60
3.1 (L1) Ensure 'deployment method retail' is set (Manual)	61
3.2 (L2) Ensure 'debug' is turned off (Automated)	63
3.3 (L2) Ensure custom error messages are not off (Automated)	65
3.4 (L1) Ensure IIS HTTP detailed errors are hidden from displaying remotely (Automated)	67
3.5 (L2) Ensure ASP.NET stack tracing is not enabled (Automated)	70
3.6 (L2) Ensure 'httpcookie' mode is configured for session state (Automated)	73
3.7 (L1) Ensure 'cookies' are set with HttpOnly attribute (Automated)	76
3.8 (L2) Ensure 'MachineKey validation method - .Net 3.5' is configured (Automated)	78
3.9 (L1) Ensure 'MachineKey validation method - .Net 4.5' is configured (Automated)	80
3.10 (L1) Ensure global .NET trust level is configured (Automated)	83
3.11 (L2) Ensure X-Powered-By Header is removed (Manual)	86
3.12 (L2) Ensure Server Header is removed (Manual)	88
4 Request Filtering and Other Restriction Modules	90
4.1 (L2) Ensure 'maxAllowedContentLength' is configured (Manual)	91
4.2 (L2) Ensure 'maxURL request filter' is configured (Automated)	94
4.3 (L2) Ensure 'MaxQueryString request filter' is configured (Automated)	97
4.4 (L2) Ensure non-ASCII characters in URLs are not allowed (Automated)	100
4.5 (L1) Ensure Double-Encoded requests will be rejected (Automated)	103
4.6 (L1) Ensure 'HTTP Trace Method' is disabled (Manual)	107
4.7 (L1) Ensure Unlisted File Extensions are not allowed (Automated)	110
4.8 (L1) Ensure Handler is not granted Write and Script/Execute (Manual)	113
4.9 (L1) Ensure 'notListedIsapisAllowed' is set to false (Automated)	116
4.10 (L1) Ensure 'notListedCgisAllowed' is set to false (Automated)	118
4.11 (L1) Ensure 'Dynamic IP Address Restrictions' is enabled (Manual)	120
5 IIS Logging Recommendations	122
5.1 (L1) Ensure Default IIS web log location is moved (Automated)	123
5.2 (L1) Ensure Advanced IIS logging is enabled (Automated)	125
5.3 (L1) Ensure 'ETW Logging' is enabled (Manual)	127
6 FTP Requests	129
6.1 (L1) Ensure FTP requests are encrypted (Manual)	130
6.2 (L1) Ensure FTP Logon attempt restrictions is enabled (Manual)	132
7 Transport Encryption	134
7.1 (L2) Ensure HSTS Header is set (Manual)	136
7.2 (L1) Ensure SSLv2 is Disabled (Automated)	139
7.3 (L1) Ensure SSLv3 is Disabled (Automated)	143
7.4 (L1) Ensure TLS 1.0 is Disabled (Automated)	147
7.5 (L1) Ensure TLS 1.1 is Disabled (Automated)	151
7.6 (L1) Ensure TLS 1.2 is Enabled (Automated)	155
7.7 (L1) Ensure NULL Cipher Suites is Disabled (Automated)	157
7.8 (L1) Ensure DES Cipher Suites is Disabled (Automated)	159
7.9 (L1) Ensure RC4 Cipher Suites is Disabled (Automated)	161
7.10 (L1) Ensure AES 128/128 Cipher Suite is Disabled (Automated)	165
7.11 (L1) Ensure AES 256/256 Cipher Suite is Enabled (Automated)	167
7.12 (L2) Ensure TLS Cipher Suite ordering is Configured (Automated)	169

<i>Appendix: Summary Table</i>	<i>173</i>
<i>Appendix: Change History</i>	<i>189</i>

Overview

All CIS Benchmarks focus on technical configuration settings used to maintain and/or increase the security of the addressed technology, and they should be used in **conjunction** with other essential cyber hygiene tasks like:

- Monitoring the base operating system for vulnerabilities and quickly updating with the latest security patches
- Monitoring applications and libraries for vulnerabilities and quickly updating with the latest security patches

In the end, the CIS Benchmarks are designed as a key **component** of a comprehensive cybersecurity program.

This document provides prescriptive guidance for establishing a secure configuration posture for Microsoft Windows IIS 10.

This secure configuration guide is based on **Microsoft Windows IIS 10** and is intended for all versions of **Microsoft Windows IIS 10**. This secure configuration guide was tested on **Microsoft Windows Server 2022 Datacenter**.

To obtain the latest version of this secure configuration guide, please visit <https://www.cisecurity.org/cis-benchmarks/>. If you have questions, comments, or have identified ways to improve this guide, please write us at feedback@cisecurity.org.

Intended Audience

This document is intended for system and application administrators, security specialists, auditors, help desk, and platform deployment personnel who plan to develop, deploy, assess, or secure solutions that incorporate Microsoft IIS 10.

Consensus Guidance

This CIS Benchmark was created using a consensus review process comprised of a global community of subject matter experts. The process combines real world experience with data-based information to create technology specific guidance to assist users to secure their environments. Consensus participants provide perspective from a diverse set of backgrounds including consulting, software development, audit and compliance, security research, operations, government, and legal.

Each CIS Benchmark undergoes two phases of consensus review. The first phase occurs during initial Benchmark development. During this phase, subject matter experts convene to discuss, create, and test working drafts of the Benchmark. This discussion occurs until consensus has been reached on Benchmark recommendations. The second phase begins after the Benchmark has been published. During this phase, all feedback provided by the Internet community is reviewed by the consensus team for incorporation in the Benchmark. If you are interested in participating in the consensus process, please visit <https://workbench.cisecurity.org/>.

Typographical Conventions

The following typographical conventions are used throughout this guide:

Convention	Meaning
<code>Stylized Monospace font</code>	Used for blocks of code, command, and script examples. Text should be interpreted exactly as presented.
<code>Monospace font</code>	Used for inline code, commands, or examples. Text should be interpreted exactly as presented.
<i><italic font in brackets></i>	Italic texts set in angle brackets denote a variable requiring substitution for a real value.
<i>Italic font</i>	Used to denote the title of a book, article, or other publication.
Note	Additional information or caveats

Recommendation Definitions

The following defines the various components included in a CIS recommendation as applicable. If any of the components are not applicable it will be noted or the component will not be included in the recommendation.

Title

Concise description for the recommendation's intended configuration.

Assessment Status

An assessment status is included for every recommendation. The assessment status indicates whether the given recommendation can be automated or requires manual steps to implement. Both statuses are equally important and are determined and supported as defined below:

Automated

Represents recommendations for which assessment of a technical control can be fully automated and validated to a pass/fail state. Recommendations will include the necessary information to implement automation.

Manual

Represents recommendations for which assessment of a technical control cannot be fully automated and requires all or some manual steps to validate that the configured state is set as expected. The expected state can vary depending on the environment.

Profile

A collection of recommendations for securing a technology or a supporting platform. Most benchmarks include at least a Level 1 and Level 2 Profile. Level 2 extends Level 1 recommendations and is not a standalone profile. The Profile Definitions section in the benchmark provides the definitions as they pertain to the recommendations included for the technology.

Description

Detailed information pertaining to the setting with which the recommendation is concerned. In some cases, the description will include the recommended value.

Rationale Statement

Detailed reasoning for the recommendation to provide the user a clear and concise understanding on the importance of the recommendation.

Impact Statement

Any security, functionality, or operational consequences that can result from following the recommendation.

Audit Procedure

Systematic instructions for determining if the target system complies with the recommendation

Remediation Procedure

Systematic instructions for applying recommendations to the target system to bring it into compliance according to the recommendation.

Default Value

Default value for the given setting in this recommendation, if known. If not known, either not configured or not defined will be applied.

References

Additional documentation relative to the recommendation.

CIS Critical Security Controls® (CIS Controls®)

The mapping between a recommendation and the CIS Controls is organized by CIS Controls version, Safeguard, and Implementation Group (IG). The Benchmark in its entirety addresses the CIS Controls safeguards of (v7) "5.1 - Establish Secure Configurations" and (v8) "4.1 - Establish and Maintain a Secure Configuration Process" so individual recommendations will not be mapped to these safeguards.

Additional Information

Supplementary information that does not correspond to any other field but may be useful to the user.

Profile Definitions

The following configuration profiles are defined by this Benchmark:

- **Level 1 - IIS 10**

Items in this profile apply to Microsoft IIS 10 running on Microsoft Windows Server 2016 and intend to:

- be practical and prudent;
- provide a clear security benefit; and
- not inhibit the utility of the technology beyond acceptable means.

- **Level 2 - IIS 10**

This profile extends the "Level 1 - IIS 10" profile. Items in this profile apply to Microsoft IIS 10.0 running on Microsoft Windows Server 2016 and exhibit one or more of the following characteristics:

- are intended for environments or use cases where security is paramount;
- acts as defense in depth measure;
- may negatively inhibit the utility or performance of the technology.

Acknowledgements

This Benchmark exemplifies the great things a community of users, vendors, and subject matter experts can accomplish through consensus collaboration. The CIS community thanks the entire consensus team with special recognition to the following individuals who contributed greatly to the creation of this guide:

Editor

Jennifer Jarose

Matthew Woods

Recommendations

1 Basic Configurations

This section contains basic Web server-level recommendations.

1.1 (L1) Ensure 'Web content' is on non-system partition (Manual)

Profile Applicability:

- Level 1 - IIS 10

Description:

Web resources published through IIS are mapped via Virtual Directories to physical locations on disk. It is recommended to map all Virtual Directories to a non-system disk volume.

Rationale:

Isolating web content from system files may reduce the probability of web sites/applications exhausting system disk space. It can also reduce the file IO vulnerability in the web site/application from affecting the confidentiality and/or integrity of system files.

Impact:

Once the configuration is changed all content from the root drive to the new drive including ACLs and empty directories will need to be copied.

Audit:

Execute the following command to ensure no virtual directories are mapped to the system drive:

To verify using AppCmd.exe enter the following command:

```
%systemroot%\system32\inetsrv\appcmd list vdir
```

OR

To verify using PowerShell enter the following command:

```
Get-Website | Format-List Name, PhysicalPath
```

Remediation:

1. Browse to web content in `C:\inetpub\wwwroot\`
2. Copy or cut content onto a dedicated and restricted web folder on a non-system drive such as `D:\webroot\`
3. Change mappings for any applications or Virtual Directories to reflect the new location

To change the mapping for the application named *app1* which resides under the Default Web Site, open IIS Manager:

1. Expand the server node
2. Expand Sites
3. Expand Default Web Site
4. Click on *app1*
5. In the Actions pane, select Basic Settings
6. In the Physical path text box, put the new location of the application, `D:\wwwroot\app1` in the example above

Default Value:

The default location for web content is: `%systemdrive%\inetpub\wwwroot`.

References:

1. <http://blogs.iis.net/thomad/archive/2008/02/10/moving-the-iis7-inetpub-directory-to-a-different-drive.aspx>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v7	14 <u>Controlled Access Based on the Need to Know</u> Controlled Access Based on the Need to Know			

1.2 (L1) Ensure 'Host headers' are on all sites (Automated)

Profile Applicability:

- Level 1 - IIS 10

Description:

Host headers provide the ability to host multiple websites on the same IP address and port. It is recommended that host headers be configured for all sites.

Note: Wildcard host headers are now supported.

Rationale:

Requiring a Host header for all sites may reduce the probability of DNS rebinding attacks successfully compromising or abusing site data or functionality and IP-based scans successfully identifying or interacting with a target application hosted on IIS.

Impact:

If a wildcard DNS entry exists and a wildcard host header is used, it may be serving data to more domains than intended.

Audit:

Execute the following command to identify sites that are not configured to require host headers:

To verify using AppCmd.exe enter the following command:

```
%systemroot%\system32\inetsrv\appcmd list sites
```

OR

To verify using PowerShell enter the following command:

```
Get-WebBinding -Port * | Format-List bindingInformation
```

All sites will be listed as such: SITE "Default Web Site"
(id:1,bindings:http/*:80:test.com,state:Started) SITE "badsite"
(id:3,bindings:http/*:80:,state:Started) For all non-SSL sites, ensure that the *IP:port:host* binding triplet contains a host name. In the example above, the first site is configured as recommended given the Default Web Site has a host header of test.com. badsite, however, does not have a host header configured - it shows *:80: which means all IPs over port 80, with no host header.

Remediation:

Obtain a listing of all sites by using the following `appcmd.exe` command:

Enter the following command in `AppCmd.exe` to configure the host header:

```
%systemroot%\system32\inetsrv\appcmd.exe set config -  
section:system.applicationHost/sites /"[name='<website  
name>'].bindings.[protocol='http',bindingInformation='*:80:<host  
header>'].bindingInformation:":*:80:<host header>" /commit:apphost
```

OR

Enter the following command in PowerShell to configure the host header:

```
Set-WebConfigurationProperty -pspath 'MACHINE/WEBROOT/APPHOST' -filter  
'system.applicationHost/sites/site[@name='<website  
name>']/bindings/binding[@protocol='http' and @bindingInformation='*:80:']' -  
name 'bindingInformation' -value '*:80:<host header value>'
```

OR

Perform the following in IIS Manager to configure host headers for the Default Web Site:

1. Open IIS Manager
2. In the Connections pane expand the Sites node and select Default Web Site
3. In the Actions pane click Bindings
4. In the Site Bindings dialog box, select the binding for which host headers are going to be configured, Port 80 in this example
5. Click Edit
6. Under host name, enter the sites FQDN, such as `<www.examplesite.com>`
7. Click OK, then Close

Note: Requiring a host header may impair site functionality for HTTP/1.0 clients.

Default Value:

By default, host headers are not required or set up automatically.

References:

1. <http://technet.microsoft.com/en-us/library/cc753195%28WS.10%29.aspx>
2. <http://crypto.stanford.edu/dns/dns-rebinding.pdf>
3. <http://www.sslshopper.com/article-ssl-host-headers-in-iis-7.html>
4. <http://blogs.iis.net/thomad/archive/2008/01/25/ssl-certificates-on-sites-with-host-headers.aspx>
5. <https://www.iis.net/learn/get-started/whats-new-in-iis-10/wildcard-host-header-support>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v7	18 <u>Application Software Security</u> Application Software Security			

1.3 (L1) Ensure 'Directory browsing' is set to Disabled (Automated)

Profile Applicability:

- Level 1 - IIS 10

Description:

Directory browsing allows the contents of a directory to be displayed upon request from a web client. If directory browsing is enabled for a directory in Internet Information Services, users receive a page that lists the contents of the directory when the following two conditions are met:

1. No specific file is requested in the URL
2. The Default Documents feature is disabled in IIS, or if it is enabled, IIS is unable to locate a file in the directory that matches a name specified in the IIS default document list

Note: If directory browsing is enabled (an exception to this recommendation), make sure that it is only enabled on the particular directory or directories that need to be shared.

Rationale:

Ensuring that directory browsing is disabled may reduce the probability of disclosing sensitive content that is inadvertently accessible via IIS.

Impact:

Users will not be able to see the contents of directories.

Audit:

Perform the following to verify that Directory Browsing has been disabled at the server level:

To verify using AppCmd.exe enter the following command:

```
%systemroot%\system32\inetsrv\appcmd list config /section:directoryBrowse
```

If the server is configured as recommended, the following will be displayed:

```
<system.webServer>
  <directoryBrowse enabled="false" />
</system.webServer>
```

OR

To verify using PowerShell enter the following command:

```
Get-WebConfigurationProperty -Filter system.webserver/directorybrowse -PSPath iis:\ -Name Enabled | select Value
```

Remediation:

Directory Browsing can be set by using the UI, running `appcmd.exe` commands, by editing configuration files directly, or by writing WMI scripts. To disable directory browsing at the server level using an `appcmd.exe` command:

Enter the following command in AppCmd.exe to configure:

```
%systemroot%\system32\inetsrv\appcmd set config /section:directoryBrowse /enabled:false
```

OR

Enter the following command in PowerShell to configure:

```
Set-WebConfigurationProperty -Filter system.webserver/directorybrowse -PSPath iis:\ -Name Enabled -Value False
```

Default Value:

In IIS, directory browsing is disabled by default.

References:

1. <http://technet.microsoft.com/en-us/library/cc725840%28WS.10%29.aspx>
2. <http://technet.microsoft.com/en-us/library/cc731109%28WS.10%29.aspx>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	<u>4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software</u> Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.			
v7	<u>18 Application Software Security</u> Application Software Security			

1.4 (L1) Ensure 'application pool identity' is configured for all application pools (Automated)

Profile Applicability:

- Level 1 - IIS 10

Description:

Application Pool Identities are the actual users/authorities that will run the worker process - `w3wp.exe`. Assigning the correct user authority will help ensure that applications can function properly, while not giving overly permissive permissions on the system. These identities can further be used in ACLs to protect system content. It is recommended that each Application Pool run under a unique identity.

IIS has additional built-in least privilege identities intended for use by Application Pools. It is recommended that the default Application Pool Identity be changed to a least privilege principle other than Network Service. Furthermore, it is recommended that all application pool identities be assigned a unique least privilege principal.

To achieve isolation in IIS, application pools can be run as separate identities. IIS can be configured to automatically use the application pool identity if no anonymous user account is configured for a Web site. This can greatly reduce the number of accounts needed for Web sites and make management of the accounts easier. It is recommended the Application Pool Identity be set as the Anonymous User Identity.

The name of the Application Pool account corresponds to the name of the Application Pool. Application Pool Identities were introduced in Windows Server 2008 SP2. It is recommended that Application Pools be set to run as `ApplicationPoolIdentity` unless there is an underlying reason that the application pool needs to run as a specified end user account. One example where this is needed is for web farms using Kerberos authentication.

Rationale:

Setting Application Pools to use unique least privilege identities such as `ApplicationPoolIdentity` reduces the potential harm the identity could cause should the application ever become compromised.

Additionally, it will simplify application pools configuration and account management.

Impact:

If Application Pool Identities are not set properly to users/authorities applications may not function properly.

Audit:

To verify the Application Pools have been set to run under the ApplicationPoolIdentity using IIS Manager:

1. Open IIS Manager
2. Open the Application Pools node underneath the machine node; select Application Pool to be verified
3. Right click the Application Pool and select Advanced Settings...
4. Under the Process Model section, locate the Identity option and ensure that ApplicationPoolIdentity is set

This configuration is stored in the same `applicationHost.config` file for web sites and application/virtual directories, at the bottom of the file, surrounded by `<location path="path/to/resource">` tags.

To verify that any new Application Pools use the ApplicationPoolIdentity, execute the following command to determine if the Application Pool default has been changed to ApplicationPoolIdentity:

To verify using AppCmd.exe enter the following command:

```
%systemroot%\system32\inetsrv\appcmd list config /section:applicationPools
```

OR

To verify using PowerShell enter the following command:

```
Get-ChildItem -Path IIS:\AppPools\ |  
Select-Object name, state, <#@{e={$_.processModel.password};l="password"}, #>  
@{e={$_.processModel.identityType};l="identityType"}
```

Remediation:

The default Application Pool identity may be set for an application using the IIS Manager GUI, using `AppCmd.exe` commands in a command-line window, directly editing the configuration files, or by writing WMI scripts. Perform the following to change the default identity to the built-in `ApplicationPoolIdentity` in the IIS Manager GUI:

1. Open the IIS Manager GUI
2. In the connections pane, expand the server node and click Application Pools
3. On the Application Pools page, select the `DefaultAppPool`, and then click Advanced Settings in the Actions pane
4. For the Identity property, click the '...' button to open the Application Pool Identity dialog box
5. Select the Built-in account option choose `ApplicationPoolIdentity` from the list, or input a unique application user created for this purpose
6. Restart IIS

To change the `ApplicationPool` identity to the built-in `ApplicationPoolIdentity` using `AppCmd.exe`, run the following from a command prompt:

Enter the following command in `AppCmd.exe` to configure

```
%systemroot%\system32\inetsrv\appcmd set config /section:applicationPools  
/[name='<apppool name>'].processModel.identityType:ApplicationPoolIdentity
```

OR

To change the `ApplicationPool` identity to the built-in `ApplicationPoolIdentity` using PowerShell:

```
Set-WebConfigurationProperty -pspath 'MACHINE/WEBROOT/APPHOST' -filter  
'system.applicationHost/applicationPools/add[@name='<apppool  
name>']/processModel' -name 'identityType' -value 'ApplicationPoolIdentity'
```

The example code above will set just the `DefaultAppPool`. Run this command for each configured Application Pool. Additionally, `ApplicationPoolIdentity` can be made the default for all Application Pools by using the Set Application Pool Defaults action on the Application Pools node.

If using a custom defined Windows user such as a dedicated service account, that user will need to be a member of the `IIS_IUSRS` group. The `IIS_IUSRS` group has access to all the necessary file and system resources so that an account, when added to this group, can seamlessly act as an application pool identity.

Default Value:

By Default, the `DefaultAppPool` in IIS is configured to use the `ApplicationPoolIdentity` account.

References:

1. <http://technet.microsoft.com/en-us/library/cc771170%28WS.10%29.aspx>
2. <http://learn.iis.net/page.aspx/140/understanding-built-in-user-and-group-accounts-in-iis-7/>
3. <http://learn.iis.net/page.aspx/624/application-pool-identities/>
4. <http://blogs.iis.net/tomwoolums/archive/2008/12/17/iis-7-0-application-pools.aspx>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	6.8 <u>Define and Maintain Role-Based Access Control</u> Define and maintain role-based access control, through determining and documenting the access rights necessary for each role within the enterprise to successfully carry out its assigned duties. Perform access control reviews of enterprise assets to validate that all privileges are authorized, on a recurring schedule at a minimum annually, or more frequently.			●
v7	18 <u>Application Software Security</u> Application Software Security			

1.5 (L1) Ensure 'unique application pools' is set for sites (Automated)

Profile Applicability:

- Level 1 - IIS 10

Description:

Application Pool Identities allows Application Pools to be run under unique accounts without the need to create and manage local or domain accounts.

It is recommended that all Sites run under unique, dedicated Application Pools.

Rationale:

By setting sites to run under unique Application Pools, resource-intensive applications can be assigned to their own application pools which could improve server and application performance. In addition, it can help maintain application availability: if an application in one pool fails, applications in other pools are not affected. Last, isolating applications helps mitigate the potential risk of one application being allowed access to the resources of another application. It is also recommended to stop any application pool that is not in use or was created by an installation such as .Net 4.0.

Impact:

All sites will need to be run under unique dedicated Application Pools.

Audit:

The following appcmd.exe command will give a listing of all applications configured, which site they are in, which application pool is serving them and which application pool identity they are running under:

```
%systemroot%\system32\inetsrv\appcmd list app
```

The output of this command will be similar to the following: APP "Default Web Site/" (applicationPool:DefaultAppPool)

Run the above command and ensure a unique application pool is assigned for each site listed.

OR

To verify using PowerShell enter the following command:

```
Get-Website | Select-Object Name, applicationPool
```

Remediation:

The following appcmd.exe command will set the application pool for a given application:

```
%systemroot%\system32\inetsrv\appcmd set app '<website name>/'  
/applicationpool:<apppool name>
```

The output of this command will be similar to the following: APP object "Default Web Site/" changed (applicationPool:DefaultAppPool)

Run the above command to ensure a unique application pool is assigned for each site listed

OR

Enter the following command in PowerShell to configure:

```
Set-ItemProperty -Path 'IIS:\Sites\<website name>' -Name applicationPool -  
Value <apppool name>
```

OR

1. Open IIS Manager
2. Open the Sites node underneath the machine node
3. Select the Site to be changed
4. In the Actions pane, select Basic Settings
5. Click the Select... box next to the Application Pool text box
6. Select the desired Application Pool
7. Once selected, click OK

Default Value:

By default, all Sites created will use the Default Application Pool (DefaultAppPool).

References:

1. <http://technet.microsoft.com/en-us/library/cc753449%28WS.10%29.aspx>
2. <http://blogs.iis.net/tomwoolums/archive/2008/12/17/iis-7-0-application-pools.aspx>
3. <http://learn.iis.net/page.aspx/624/application-pool-identities/>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v7	14.6 <u>Protect Information through Access Control Lists</u> Protect all information stored on systems with file system, network share, claims, application, or database specific access control lists. These controls will enforce the principle that only authorized individuals should have access to the information based on their need to access the information as a part of their responsibilities.			

1.6 (L1) Ensure 'application pool identity' is configured for anonymous user identity (Automated)

Profile Applicability:

- Level 1 - IIS 10

Description:

To achieve isolation in IIS, application pools can be run as separate identities. IIS can be configured to automatically use the application pool identity if no anonymous user account is configured for a web site. This can greatly reduce the number of accounts needed for Web sites and make management of the accounts easier.

It is recommended the Application Pool Identity be set as the Anonymous User Identity.

Rationale:

Configuring the anonymous user identity to use the application pool identity will help ensure site isolation - provided sites are set to use the application pool identity. Since a unique principal will run each application pool, it will ensure the identity is least privilege. Additionally, it will simplify Site management.

Impact:

N/A

Audit:

Find and open the `applicationHost.config` file and verify that the `userName` attribute of the `anonymousAuthentication` tag is set to a blank string:

```
<system.webServer>
  <security>
    <authentication>
      <anonymousAuthentication userName="" />
    </authentication>
  </security>
</system.webServer>
```

This configuration is stored in the same `applicationHost.config` file for web sites and application/virtual directories, at the bottom of the file, surrounded by `<location path="/path/to/resource">` tags.

To verify using PowerShell enter the following command:

```
Get-WebConfiguration
system.webServer/security/authentication/anonymousAuthentication -Recurse |
where {$_.enabled -eq $true} | format-list location
```

Remediation:

The Anonymous User Identity can be set to Application Pool Identity by using the IIS Manager GUI, using `AppCmd.exe` commands in a command-line window, directly editing the configuration files, or by writing WMI scripts. Perform the following to set the username attribute of the `anonymousAuthentication` node in the IIS Manager GUI:

1. Open the IIS Manager GUI and navigate to the desired server, site, or application
2. In Features View, find and double-click the Authentication icon
3. Select the Anonymous Authentication option and in the Actions pane select Edit...
4. Choose Application pool identity in the modal window and then press the OK button

OR

To use `AppCmd.exe` to configure `anonymousAuthentication` at the server level, the command would look like this:

```
%systemroot%\system32\inetsrv\appcmd set config -  
section:anonymousAuthentication /username:"" --password
```

OR

Enter the following command in PowerShell to configure:

```
Set-ItemProperty -Path IIS:\AppPools\<apppool name> -Name passAnonymousToken  
-Value True
```

Default Value:

The default identity for the anonymous user is the IUSR virtual account.

References:

1. <http://learn.iis.net/page.aspx/202/application-pool-identity-as-anonymous-user/>
2. <http://learn.iis.net/page.aspx/624/application-pool-identities/>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v7	14.6 Protect Information through Access Control Lists Protect all information stored on systems with file system, network share, claims, application, or database specific access control lists. These controls will enforce the principle that only authorized individuals should have access to the information based on their need to access the information as a part of their responsibilities.			

1.7 (L1) Ensure' WebDav' feature is disabled (Automated)

Profile Applicability:

- Level 1 - IIS 10

Description:

WebDAV is an extension to the HTTP protocol which allows clients to create, move, and delete files and resources on the web server.

Note: The WebDAV feature must be enabled for this functionality to be available in IIS.

Rationale:

WebDAV is not widely used, and it has serious security concerns because it may allow clients to modify unauthorized files on the web server. Therefore, the WebDav feature should be disabled.

Impact:

The WebDav feature will not be available in IIS.

Audit:

To verify using PowerShell, enter the following command:

```
Install-WindowsFeature Web-DAV-Publishing
```

Verify that the Install State is Available

Remediation:

To disable this feature using PowerShell, enter the following command:

```
Uninstall-WindowsFeature Web-DAV-Publishing
```

Verify that Success is True

Default Value:

The default state of WebDAV Publishing is disabled

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	<u>4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software</u> Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.			
v8	<u>16.10 Apply Secure Design Principles in Application Architectures</u> Apply secure design principles in application architectures. Secure design principles include the concept of least privilege and enforcing mediation to validate every operation that the user makes, promoting the concept of "never trust user input." Examples include ensuring that explicit error checking is performed and documented for all input, including for size, data type, and acceptable ranges or formats. Secure design also means minimizing the application infrastructure attack surface, such as turning off unprotected ports and services, removing unnecessary programs and files, and renaming or removing default accounts.			
v7	<u>9.2 Ensure Only Approved Ports, Protocols and Services Are Running</u> Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.			

2 Configure Authentication and Authorization

This section contains recommendations around the different layers of authentication in IIS.

2.1 (L1) Ensure 'global authorization rule' is set to restrict access (Manual)

Profile Applicability:

- Level 1 - IIS 10

Description:

IIS introduced URL Authorization, which allows the addition of Authorization rules to the actual URL, instead of the underlying file system resource, as a way to protect it. Authorization rules can be configured at the server, web site, folder (including Virtual Directories), or file level. The native URL Authorization module applies to all requests, whether they are .NET managed or other types of files (e.g., static files or ASP files). It is recommended that URL Authorization be configured to only grant access to the necessary security principals.

Rationale:

Configuring a global Authorization rule that restricts access will ensure inheritance of the settings down through the hierarchy of web directories; if that content is copied elsewhere, the authorization rules flow with it. This will ensure access to current and future content is only granted to the appropriate principals, mitigating risk of accidental or unauthorized access.

Impact:

If not set properly, the authorization rule could restrict access at a level that is not intended to be restricted.

Audit:

Verify an authorization rule specifying no access to all users except the Administrators group:

To verify using AppCmd.exe enter the following command:

```
%systemroot%\system32\inetsrv\appcmd list config -  
section:system.webserver/security/authorization
```

OR

To verify using PowerShell enter the following command:

```
Get-WebConfiguration -pspath 'IIS:\' -filter  
'system.webServer/security/authorization'
```

OR

At the web site or application level, verify that the authorization rule configured has been applied:

1. Connect to Internet Information Services (IIS Manager)
2. Select the site or application where Authorization was configured
3. Select Authorization Rules and verify the configured rules were added

Browse to and open the `web.config` file for the configured site/application/content:

```
<configuration>  
  <system.webServer>  
    <security>  
      <authorization>  
        <remove users="*" roles="" verbs="" />  
        <add accessType="Allow" roles="administrators" />  
      </authorization>  
    </security>  
  </system.webServer>  
</configuration>
```

Remediation:

To configure URL Authorization at the server level using command line utilities:
Enter the following command in AppCmd.exe to configure:

```
%systemroot%\system32\inetsrv\appcmd set config -  
section:system.webServer/security/authorization /-  
"[users='*',roles='',verbs='']"  
%systemroot%\system32\inetsrv\appcmd set config -  
section:system.webServer/security/authorization  
/+"[accessType='Allow',roles='Administrators']"
```

OR

Enter the following command in PowerShell to configure:

```
Remove-WebConfigurationProperty -pspath 'MACHINE/WEBROOT/APPHOST' -filter  
"system.webServer/security/authorization" -name "." -AtElement  
{users='*';roles='';verbs=''}  
Add-WebConfigurationProperty -pspath 'MACHINE/WEBROOT/APPHOST' -filter  
"system.webServer/security/authorization" -name "." -value  
{accessType='Allow';roles='Administrators'}
```

OR

To configure URL Authorization at the server level using IIS Manager:

1. Connect to Internet Information Services (IIS Manager)
2. Select the server
3. Select Authorization Rules
4. Remove the "Allow All Users" rule
5. Click Add Allow Rule...
6. Allow access to the user(s), user groups, or roles that are authorized across all of the web sites and applications (e.g. the Administrators group)

Default Value:

The default server-level setting is to allow all users access.

References:

1. <http://www.iis.net/learn/manage/configuring-security/understanding-iis-url-authorization>
2. <http://www.iis.net/learn/get-started/whats-new-in-iis-7/changes-in-security-between-iis-60-and-iis-7-and-above#Authorization>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.3 <u>Configure Data Access Control Lists</u> Configure data access control lists based on a user's need to know. Apply data access control lists, also known as access permissions, to local and remote file systems, databases, and applications.			
v7	18 <u>Application Software Security</u> Application Software Security			

2.2 (L1) Ensure access to sensitive site features is restricted to authenticated principals only (Manual)

Profile Applicability:

- Level 1 - IIS 10

Description:

IIS supports both challenge-based and login redirection-based authentication methods. Challenge-based authentication methods, such as Integrated Windows Authentication, require a client to respond correctly to a server-initiated challenge. A login redirection-based authentication method such as Forms Authentication relies on redirection to a login page to determine the identity of the principal. Challenge-based authentication and login redirection-based authentication methods cannot be used in conjunction with one another.

Public servers/sites are typically configured to use Anonymous Authentication. This method typically works, provided the content or services is intended for use by the public. When sites, applications, or specific content containers are not intended for anonymous public use, an appropriate authentication mechanism should be utilized. Authentication will help confirm the identity of clients who request access to sites, application, and content. IIS provides the following authentication modules by default:

- Anonymous Authentication - allows anonymous users to access sites, applications, and/or content
- Integrated Windows Authentication - authenticates users using the NTLM or Kerberos protocols; Kerberos v5 requires a connection to Active Directory
- ASP.NET Impersonation - allows ASP.NET applications to run under a security context different from the default security context for an application
- Forms Authentication - enables a user to login to the configured space with a valid username and password which is then validated against a database or other credentials store
- Basic authentication - requires a valid username and password to access content
- Client Certificate Mapping Authentication - allows automatic authentication of users who log on with client certificates that have been configured; requires SSL
- Digest Authentication - uses Windows domain controller to authenticate users who request access

Note that none of the challenge-based authentication modules can be used at the same time Forms Authentication is enabled for certain applications/content. Forms Authentication does not rely on IIS authentication, so anonymous access for the ASP.NET application can be configured if Forms Authentication will be used.

It is recommended that sites containing sensitive information, confidential data, or non-public web services be configured with a credentials-based authentication mechanism.

Rationale:

Configuring authentication will help mitigate the risk of unauthorized users accessing data and/or services, and in some cases reduce the potential harm that can be done to a system.

Impact:

Authentication will be restricted to the method that is applied.

Audit:

To verify that the authentication module is enabled for a specific site, application, or content, browse to and open the `web.config` file pertaining to the content. Verify the configuration file now has a mode defined within the `<authentication>` tags. The example below shows that Forms Authentication is configured, cookies will always be used, and SSL is required:

```
<system.web>
  <authentication>
    <forms cookieless="UseCookies" requireSSL="true" />
  </authentication>
</system.web>
```

OR

To verify using AppCmd.exe enter the following command:

```
%systemroot%\system32\inetsrv\appcmd list config -
section:system.web/authentication
```

OR

To verify using PowerShell enter the following command:

```
Get-WebConfiguration system.webServer/security/authentication/* -Recurse |
Where-Object {$_.enabled -eq $true} | Format-Table
```


Remediation:

When configuring an authentication module for the first time, each mechanism must be completely configured before use.

Enabling authentication can be performed by using the user interface (UI), running `AppCmd.exe` commands in a command-line window, editing configuration files directly, or by writing WMI scripts. To verify an authentication mechanism is in place for sensitive content using the IIS Manager GUI:

1. Open IIS Manager and navigate to level with sensitive content
2. In Features View, double-click Authentication
3. On the Authentication page, make sure an authentication module is enabled, while anonymous authentication is enabled (Forms Authentication can have anonymous as well)
4. If necessary, select the desired authentication module, then in the Actions pane, click Enable

OR

Enter the following command in `AppCmd.exe` to configure:

```
%systemroot%\system32\inetsrv\appcmd set config -  
section:system.web/authentication /mode:<Windows|Passport|Forms>
```

OR

Enter the following command in PowerShell to configure:

```
Set-WebConfigurationProperty -pspath 'MACHINE/WEBROOT/APPHOST' -location  
'<website location>' -filter  
'system.webServer/security/authentication/anonymousAuthentication' -name  
'enabled' -value 'False'  
Set-WebConfigurationProperty -pspath 'MACHINE/WEBROOT/APPHOST' -location  
'<website location>' -filter  
'system.webServer/security/authentication/windowsAuthentication' -name  
'enabled' -value 'True'
```

Default Value:

The default installation of IIS supports Anonymous Authentication without further electing additional methods.

References:

1. <http://learn.iis.net/page.aspx/377/using-aspnet-forms-authentication/rev/1>
2. <http://learn.iis.net/page.aspx/244/how-to-take-advantage-of-the-iis7-integrated-pipeline/>
3. <http://technet.microsoft.com/en-us/library/cc733010%28WS.10%29.aspx>
4. <http://msdn.microsoft.com/en-us/library/aa480476.aspx>
5. [https://technet.microsoft.com/en-us/library/hh831496\(v=ws.11\).aspx](https://technet.microsoft.com/en-us/library/hh831496(v=ws.11).aspx)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v7	14.6 <u>Protect Information through Access Control Lists</u> Protect all information stored on systems with file system, network share, claims, application, or database specific access control lists. These controls will enforce the principle that only authorized individuals should have access to the information based on their need to access the information as a part of their responsibilities.			

2.3 (L1) Ensure 'forms authentication' require SSL (Automated)

Profile Applicability:

- Level 1 - IIS 10

Description:

Forms-based authentication can pass credentials across the network in clear text. It is therefore imperative that the traffic between client and server be encrypted using SSL, especially in cases where the site is publicly accessible. It is recommended that communications with any portion of a site using Forms Authentication be encrypted using SSL.

NOTE Due to identified security vulnerabilities, SSL no longer provides adequate protection for a sensitive information.

Rationale:

Requiring SSL for Forms Authentication will protect the confidentiality of credentials during the login process, helping mitigate the risk of stolen user information.

Impact:

None.

Audit:

To verify that SSL is required for forms authentication for a specific site, application, or content, browse to and open the `web.config` file for the level in which forms authentication was enabled. Verify the tag `<forms requireSSL="true" />`:

```
<system.web>
  <authentication>
    <forms requireSSL="true" />
  </authentication>
</system.web>
```

OR

To verify using AppCmd.exe enter the following command:

```
%systemroot%\system32\inetsrv\appcmd list config -
section:system.web/authentication
```

OR

To verify using PowerShell enter the following command:

```
Get-WebConfigurationProperty -pspath 'MACHINE/WEBROOT/APPHOST/Default Web
Site' -filter 'system.web/authentication/forms' -name 'requireSSL' | Format-
Table Name, Value
```

Remediation:

1. Open IIS Manager and navigate to the appropriate tier
2. In Features View, double-click Authentication
3. On the Authentication page, select Forms Authentication
4. In the Actions pane, click Edit
5. Check the Requires SSL checkbox in the cookie settings section, click OK

OR

Enter the following command in AppCmd.exe to configure:

```
%systemroot%\system32\inetsrv\appcmd set config -  
section:system.web/authentication /mode:Forms
```

OR

Enter the following command in PowerShell to configure:

```
Set-WebConfigurationProperty -pspath 'MACHINE/WEBROOT/APPHOST/Default Web  
Site' -filter 'system.web/authentication/forms' -name 'requireSSL' -value  
'True'
```

Default Value:

SSL is not required when Forms Authentication is enabled.

References:

1. [http://technet.microsoft.com/en-us/library/cc771077\(WS.10\).aspx](http://technet.microsoft.com/en-us/library/cc771077(WS.10).aspx)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.10 <u>Encrypt Sensitive Data in Transit</u> Encrypt sensitive data in transit. Example implementations can include: Transport Layer Security (TLS) and Open Secure Shell (OpenSSH).			
v7	14.4 <u>Encrypt All Sensitive Information in Transit</u> Encrypt all sensitive information in transit.			

2.4 (L2) Ensure 'forms authentication' is set to use cookies (Automated)

Profile Applicability:

- Level 2 - IIS 10

Description:

Forms Authentication can be configured to maintain the site visitor's session identifier in either a URI or cookie. It is recommended that Forms Authentication be set to use cookies.

Rationale:

Using cookies to manage session state may help mitigate the risk of session hi-jacking attempts by preventing ASP.NET from having to move session information to the URL. Moving session information identifiers into the URL may cause session IDs to show up in proxy logs, browsing history, and be accessible to client scripting via `document.location`.

Impact:

Site visitor's session identifier will be stored via cookies.

Audit:

Locate and open the `web.config` for the configured application. Verify the presence of `<forms cookieless="UseCookies" />`.

```
<system.web>
  <authentication>
    <forms cookieless="UseCookies" requireSSL="true" timeout="30" />
  </authentication>
</system.web>
```

OR

To verify using `AppCmd.exe` enter the following command:

```
%systemroot%\system32\inetsrv\appcmd list config -
section:system.web/authentication
```

OR

To verify using PowerShell enter the following command:

```
Get-WebConfigurationProperty -pspath 'MACHINE/WEBROOT/APPHOST/Default Web
Site' -filter 'system.web/authentication/forms' -Recurse -name 'cookieless'
```

Remediation:

1. Open IIS Manager and navigate to the level where Forms Authentication is enabled
2. In Features View, double-click Authentication
3. On the Authentication page, select Forms Authentication
4. In the Actions pane, click Edit
5. In the Cookie settings section, select Use cookies from the Mode dropdown

OR

Enter the following command in AppCmd.exe to configure:

```
%systemroot%\system32\inetsrv\appcmd set config -  
section:system.web/authentication /forms.cookieless:"UseCookies"
```

OR

Enter the following command in PowerShell to configure:

```
Set-WebConfigurationProperty -pspath 'MACHINE/WEBROOT/APPHOST/Default Web  
Site' -filter 'system.web/authentication/forms' -name 'cookieless' -value  
'UseCookies'
```

Default Value:

The default setting for Cookie Mode is Auto Detect which will only use cookies if the device profile supports cookies.

References:

1. <http://technet.microsoft.com/en-us/library/cc732830%28WS.10%29.aspx>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v7	18 <u>Application Software Security</u> Application Software Security			

2.5 (L1) Ensure 'cookie protection mode' is configured for forms authentication (Automated)

Profile Applicability:

- Level 1 - IIS 10

Description:

The cookie protection mode defines the protection Forms Authentication cookies will be given within a configured application. The four cookie protection modes that can be defined are:

- Encryption and validation - Specifies that the application use both data validation and encryption to help protect the cookie; this option uses the configured data validation algorithm (based on the machine key) and triple-DES (3DES) for encryption, if available and if the key is long enough (48 bytes or more)
- None - Specifies that both encryption and validation are disabled for sites that are using cookies only for personalization and have weaker security requirements
- Encryption - Specifies that the cookie is encrypted by using Triple-DES or DES, but data validation is not performed on the cookie; cookies used in this manner might be subject to plain text attacks
- Validation - Specifies that a validation scheme verifies that the contents of an encrypted cookie have not been changed in transit

It is recommended that cookie protection mode always encrypt and validate Forms Authentication cookies.

Rationale:

By encrypting and validating the cookie, the confidentiality and integrity of data within the cookie is assured. This helps mitigate the risk of attacks such as session hijacking and impersonation.

Impact:

Protection Forms Authentication cookies will be restricted to the mode defined.

Audit:

Locate and open the `web.config` for the configured application. Verify the presence of `<forms protection="All" />`.

```
<system.web>
  <authentication>
    <forms cookieless="UseCookies" protection="All" />
  </authentication>
</system.web>
```

The `protection="All"` property will only show up if cookie protection mode was set to something different, and then changed to Encryption and validation. To truly verify the `protection="All"` property in the `web.config`, the protection mode can be changed, and then changed back. Conversely, the `protection="All"` line can be added to the `web.config` manually.

OR

To verify using PowerShell enter the following command:

```
Get-WebConfigurationProperty -pspath 'MACHINE/WEBROOT/APPHOST/<website name>'
-filter 'system.web/authentication/forms' -name 'protection'
```

Remediation:

Cookie protection mode can be configured by using the user interface (UI), by running `Appcmd.exe` commands in a command-line window, by editing configuration files directly, or by writing WMI scripts. Using IIS Manager:

1. Open IIS Manager and navigate to the level where Forms Authentication is enabled
2. In Features View, double-click Authentication
3. On the Authentication page, select Forms Authentication
4. In the Actions pane, click Edit
5. In the Cookie settings section, verify the drop-down for Protection mode is set for Encryption and validation

OR

Enter the following command in PowerShell to configure:

```
Set-WebConfigurationProperty -pspath 'MACHINE/WEBROOT/APPHOST/<website name>'
-filter 'system.web/authentication/forms' -name 'protection' -value 'All'
```

Default Value:

When cookies are used for Forms Authentication, the default cookie protection mode is `All`, meaning the application encrypts and validates the cookie.

References:

1. <http://technet.microsoft.com/en-us/library/cc731804%28WS.10%29.aspx>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.11 <u>Encrypt Sensitive Data at Rest</u> Encrypt sensitive data at rest on servers, applications, and databases containing sensitive data. Storage-layer encryption, also known as server-side encryption, meets the minimum requirement of this Safeguard. Additional encryption methods may include application-layer encryption, also known as client-side encryption, where access to the data storage device(s) does not permit access to the plain-text data.			
v7	18 <u>Application Software Security</u> Application Software Security			

2.6 (L1) Ensure transport layer security for 'basic authentication' is configured (Automated)

Profile Applicability:

- Level 1 - IIS 10

Description:

Basic Authentication can pass credentials across the network in clear text. It is therefore imperative that the traffic between client and server be encrypted, especially in cases where the site is publicly accessible and is recommended that TLS be configured and required for any Site or Application using Basic Authentication.

Rationale:

Credentials sent in clear text can be easily intercepted by malicious code or persons. Enforcing the use of Transport Layer Security will help mitigate the chances of hijacked credentials.

Impact:

Credentials will not be passed across the network in plain text.

Audit:

Once transport layer security has been configured and required for a Site or application, only the https:// address will be available. Attempt loading the Site or application for which Basic Authentication is configured using http://, the requests will fail and IIS will throw a 403.4 - Forbidden error.

OR

To verify using PowerShell enter the following command:

```
Get-WebConfigurationProperty -pspath 'MACHINE/WEBROOT/APPHOST' -location '<website name>' -filter 'system.webServer/security/access' -name 'sslFlags'
```

Remediation:

To protect Basic Authentication with transport layer security:

1. Open IIS Manager
2. In the Connections pane on the left, select the server to be configured
3. In the Connections pane, expand the server, then expand Sites and select the site to be configured
4. In the Actions pane, click Bindings; the Site Bindings dialog appears
5. If an HTTPS binding is available, click Close and see below "To require SSL"
6. If no HTTPS binding is visible, perform the following steps

To add an HTTPS binding:

1. In the Site Bindings dialog, click Add; the Add Site Binding dialog appears
2. Under Type, select https
3. Under SSL certificate, select an X.509 certificate
4. Click OK, then close

To require SSL:

1. In Features View, double-click SSL Settings
2. On the SSL Settings page, select Require SSL.
3. In the Actions pane, click Apply

OR

Enter the following command in PowerShell to configure:

```
Set-WebConfigurationProperty -pspath 'MACHINE/WEBROOT/APPHOST' -location '<website name>' -filter 'system.webServer/security/access' -name 'sslFlags' -value 'Ssl'
```

Default Value:

Transport Layer Security is not enabled by default when Basic Authentication is configured.

References:

1. <http://technet.microsoft.com/en-us/library/dd378853%28WS.10%29.aspx>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.10 <u>Encrypt Sensitive Data in Transit</u> Encrypt sensitive data in transit. Example implementations can include: Transport Layer Security (TLS) and Open Secure Shell (OpenSSH).			
v7	14.4 <u>Encrypt All Sensitive Information in Transit</u> Encrypt all sensitive information in transit.			

2.7 (L1) Ensure 'passwordFormat' is not set to clear (Automated)

Profile Applicability:

- Level 1 - IIS 10

Description:

The `<credentials>` element of the `<authentication>` element allows optional definitions of name and password for IIS Manager User accounts within the configuration file. Forms based authentication also uses these elements to define the users. IIS Manager Users can use the administration interface to connect to sites and applications in which they've been granted authorization.

Note: The `<credentials>` element only applies when the default provider, `ConfigurationAuthenticationProvider`, is configured as the authentication provider.

It is recommended that `passwordFormat` be set to a value other than `Clear`, such as `SHA1`.

Rationale:

Authentication credentials should always be protected to reduce the risk of stolen authentication credentials.

Impact:

`passwordFormat` will be encrypted.

Audit:

Locate and open the configuration file for the configured application. Verify the `credentials` element is not present:

```
<configuration>
  <system.web>
    <authentication mode="Forms">
      <forms name="SampleApp" loginUrl="/login.aspx">
        <credentials passwordFormat="SHA1">
          <user
            name="<em>UserName1</em>"
            password="<em>SHA1EncryptedPassword1</em>" />
          <user
            name="<em>UserName2</em>"
            password="<em>SHA1EncryptedPassword2</em>" />
        </credentials>
      </forms>
    </authentication>
  </system.web>
</configuration>
```

OR

To verify using PowerShell enter the following command:

```
Get-WebConfigurationProperty -pspath 'MACHINE/WEBROOT/APPHOST/<website name>'
-filter 'system.web/authentication/forms/credentials' -name 'passwordFormat'
```

Remediation:

Authentication mode is configurable at the `machine.config`, root-level `web.config`, or application-level `web.config`:

1. Locate and open the configuration file where the credentials are stored
2. Find the `<credentials>` element
3. If present, ensure `passwordFormat` is not set to `Clear`
4. Change `passwordFormat` to `SHA1`

The clear text passwords will need to be replaced with the appropriate hashed version.

OR

Enter the following command in PowerShell to configure:

```
Set-WebConfigurationProperty -pspath 'MACHINE/WEBROOT/APPHOST/<website name>'
-filter 'system.web/authentication/forms/credentials' -name 'passwordFormat'
-value 'SHA1'
```

Default Value:

The default `passwordFormat` method is `SHA1`.

References:

1. <http://www.iis.net/ConfigReference/system.webServer/management/authentication/credentials>
2. <http://msdn.microsoft.com/en-us/library/bb422401%28VS.90%29.aspx>
3. <https://docs.microsoft.com/en-us/dotnet/framework/whats-new/#v471>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.11 <u>Encrypt Sensitive Data at Rest</u> Encrypt sensitive data at rest on servers, applications, and databases containing sensitive data. Storage-layer encryption, also known as server-side encryption, meets the minimum requirement of this Safeguard. Additional encryption methods may include application-layer encryption, also known as client-side encryption, where access to the data storage device(s) does not permit access to the plain-text data.			
v7	16.4 <u>Encrypt or Hash all Authentication Credentials</u> Encrypt or hash with a salt all authentication credentials when stored.			

2.8 (L2) Ensure 'credentials' are not stored in configuration files (Automated)

Profile Applicability:

- Level 2 - IIS 10

Description:

The `<credentials>` element of the `<authentication>` element allows optional definitions of name and password for IIS Manager User accounts within the configuration file. Forms based authentication also uses these elements to define the users. IIS Manager Users can use the administration interface to connect to sites and applications in which they've been granted authorization.

Note: The `<credentials>` element only applies when the default provider, `ConfigurationAuthenticationProvider`, is configured as the authentication provider.

It is recommended to avoid storing passwords in the configuration file even in form of hash.

Rationale:

Authentication credentials should always be protected to reduce the risk of stolen authentication credentials. For security reasons, it is recommended that user credentials not be stored in any IIS configuration files.

Impact:

Passwords in the configuration file will be stored in form of a hash.

Audit:

Locate and open the configuration file for the configured application. Verify the `credentials` element is not present:

```
<configuration>
  <system.web>
    <authentication mode="Forms">
      <forms name="SampleApp" loginUrl="/login.aspx">
      </forms>
    </authentication>
  </system.web>
</configuration>
```

OR

To verify using PowerShell enter the following command:

```
Get-WebConfigurationProperty -pspath 'MACHINE/WEBROOT/APPHOST/<website name>'
-filter 'system.web/authentication/forms/credentials' -name 'passwordFormat'
```

Remediation:

Authentication mode is configurable at the `machine.config`, root-level `web.config`, or application-level `web.config`:

1. Locate and open the configuration file where the credentials are stored
2. Find the `<credentials>` element
3. If present, remove the section

This will remove all references to stored users in the configuration files.

OR

Enter the following command in PowerShell to configure:

```
Remove-WebConfigurationProperty -pspath 'MACHINE/WEBROOT/APPHOST/<website
name>' -filter 'system.web/authentication/forms/credentials' -name '.'
```

References:

1. <http://www.iis.net/ConfigReference/system.webServer/management/authentication/credentials>
2. <http://msdn.microsoft.com/en-us/library/bb422401%28VS.90%29.aspx>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v7	16.4 <u>Encrypt or Hash all Authentication Credentials</u> Encrypt or hash with a salt all authentication credentials when stored.			

3 ASP.NET Configuration Recommendations

This section contains recommendations specific to ASP.NET.

3.1 (L1) Ensure 'deployment method retail' is set (Manual)

Profile Applicability:

- Level 1 - IIS 10

Description:

The `<deployment retail>` switch is intended for use by production IIS servers. This switch is used to help applications run with the best possible performance and least possible security information leakages by disabling the application's ability to generate trace output on a page, disabling the ability to display detailed error messages to end users, and disabling the debug switch. Often times, switches and options that are developer-focused, such as failed request tracing and debugging, are enabled during active development.

It is recommended that the deployment method on any production server be set to `retail`.

Rationale:

Utilizing the switch specifically intended for production IIS servers will eliminate the risk of vital application and system information leakages that would otherwise occur if tracing or debug were to be left enabled, or `customErrors` were to be left off.

Impact:

N/A

Audit:

After the next time IIS is restarted, open the `machine.config` file and verify that `<deployment retail="true" />` remains set to `true`.

```
<system.web>
  <deployment retail="true" />
</system.web>
```

Remediation:

1. Open the `machine.config` file located in:
%systemroot%\Microsoft.NET\Framework<bitness (if not the 32 bit)>\<framework version>\CONFIG
2. Add the line `<deployment retail="true" />` within the `<system.web>` section
3. If systems are 64-bit, do the same for the `machine.config` located in:
%systemroot%\Microsoft.NET\Framework<bitness (if not the 32 bit)>\<framework version>\CONFIG

Default Value:

The `<deployment retail>` tag is not included in the `machine.config` by default.

References:

1. <http://msdn.microsoft.com/en-US/library/ms228298%28VS.80%29.aspx>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v7	18 <u>Application Software Security</u> Application Software Security			

3.2 (L2) Ensure 'debug' is turned off (Automated)

Profile Applicability:

- Level 2 - IIS 10

Description:

Developers often enable the debug mode during active ASP.NET development so that they do not have to continually clear their browsers cache every time they make a change to a resource handler. The problem would arise from this being left "on" or set to "true". Compilation debug output is displayed to the end user, allowing malicious persons to obtain detailed information about applications.

This is a defense in depth recommendation due to the `<deployment retail="true" />` in the `machine.config` configuration file overriding any debug settings.

It is recommended that debugging still be turned off.

Rationale:

Setting `<compilation debug>` to `false` ensures that detailed error information does not inadvertently display during live application usage, mitigating the risk of application information leakage falling into unscrupulous hands.

Impact:

Debugging will be disabled.

Audit:

Browse to and open the `web.config` file pertaining to the server or specific application that has been configured. Locate the `<compilation debug>` switch and verify it is set to `false`.

```
<configuration>
  <system.web>
    <compilation debug="false" />
  </system.web>
</configuration>
```

OR

To verify using PowerShell enter the following command:

```
Get-WebConfigurationProperty -pspath 'MACHINE/WEBROOT/APPHOST/<website name>'
-filter "system.web/compilation" -name "debug" | format-list Name, Value
```


Remediation:

To use the UI to make this change:

1. Open IIS Manager and navigate desired server, site, or application
2. In Features View, double-click .NET Compilation
3. On the .NET Compilation page, in the Behavior section, ensure the Debug field is set to False
4. When finished, click Apply in the Actions pane

Note: The `<compilation debug>` switch will not be present in the `web.config` file unless it has been added manually, or has previously been configured using the IIS Manager GUI.

OR

Enter the following command in PowerShell to configure:

```
Set-WebConfigurationProperty -pspath 'MACHINE/WEBROOT/APPHOST/<website name>'  
-filter "system.web/compilation" -name "debug" -value "False"
```

Default Value:

The compilation of debug binaries is not enabled by default.

References:

1. <http://technet.microsoft.com/en-us/library/cc725812%28WS.10%29.aspx>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v7	18 <u>Application Software Security</u> Application Software Security			

3.3 (L2) Ensure custom error messages are not off (Automated)

Profile Applicability:

- Level 2 - IIS 10

Description:

When an ASP.NET application fails and causes an HTTP/1.x 500 Internal Server Error, or a feature configuration (such as Request Filtering) prevents a page from being displayed, an error message will be generated. Administrators can choose whether or not the application should display a friendly message to the client, detailed error message to the client, or detailed error message to localhost only. The `<customErrors>` tag in the `web.config` has three modes:

- On: Specifies that custom errors are enabled. If no `defaultRedirect` attribute is specified, users see a generic error. The custom errors are shown to the remote clients and to the local host
- Off: Specifies that custom errors are disabled. The detailed ASP.NET errors are shown to the remote clients and to the local host
- RemoteOnly: Specifies that custom errors are shown only to the remote clients, and that ASP.NET errors are shown to the local host. This is the default value

This is a defense in depth recommendation due to the `<deployment retail="true" />` in the `machine.config` file overriding any settings for `customErrors` to be turned Off.

It is recommended that `customErrors` still be turned to On or RemoteOnly.

Rationale:

`customErrors` can be set to On or RemoteOnly without leaking detailed application information to the client. Ensuring that `customErrors` is not set to Off will help mitigate the risk of malicious persons learning detailed application error and server configuration information.

Impact:

N/A

Audit:

Find and open the `web.config` file for the application/site and verify that the tag has either `<customErrors mode="RemoteOnly" />` or `<customErrors mode="On" />` defined.

OR

To verify using PowerShell enter the following command:

```
Get-WebConfigurationProperty -pspath 'MACHINE/WEBROOT/APPHOST/<website name>'  
-filter "system.web/customErrors" -name "mode"
```

Remediation:

`customErrors` may be set for a server, site, or application using the IIS Manager GUI, using `AppCmd.exe` commands in a command-line window, directly editing the configuration files, or by writing WMI scripts. Perform the following to set the `customErrors mode` to `RemoteOnly` or `On` for a Web Site in the IIS Manager GUI:

1. Open the IIS Manager GUI and navigate to the site to be configured
2. In Features View, find and double-click .NET Error Pages icon
3. In the Actions Pane, click Edit Feature Settings
4. In modal dialog, choose On or Remote Only for Mode settings
5. Click OK

OR

Enter the following command in PowerShell to configure:

```
Set-WebConfigurationProperty -pspath 'MACHINE/WEBROOT/APPHOST/Default Web  
Site' -filter "system.web/customErrors" -name "mode" -value "RemoteOnly"
```

Default Value:

The default value is `<customErrors mode="RemoteOnly" />`.

References:

1. <http://technet.microsoft.com/en-us/library/dd569096%28WS.10%29.aspx>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v7	18 <u>Application Software Security</u> Application Software Security			

3.4 (L1) Ensure IIS HTTP detailed errors are hidden from displaying remotely (Automated)

Profile Applicability:

- Level 1 - IIS 10

Description:

A Web site's error pages are often set to show detailed error information for troubleshooting purposes during testing or initial deployment. To prevent unauthorized users from viewing this privileged information, detailed error pages must not be seen by remote users. This setting can be modified in the `errorMode` attribute setting for a Web site's error pages. By default, the `errorMode` attribute is set in the `Web.config` file for the Web site or application and is located in the `<httpErrors>` element of the `<system.webServer>` section.

It is recommended that custom errors be prevented from displaying remotely.

Rationale:

The information contained in custom error messages can provide clues as to how applications function, opening up unnecessary attack vectors. Ensuring custom errors are never displayed remotely can help mitigate the risk of malicious persons obtaining information as to how the application works.

Impact:

Custom errors will not be viewable remotely.

Audit:

The `errorMode` attribute is set in the `Web.config` file for the Web site or application in the `<httpErrors>` element of the `<system.webServer>` section. Browse to the `web.config` and verify the `errorMode` is set to `DetailedLocalOnly` or `Custom`:

```
<system.web>
  <system.webServer>
    <httpErrors errorMode="DetailedLocalOnly">
    </httpErrors>
  </system.webServer>
</system.web>
```

OR

To verify using PowerShell enter the following command:

```
Get-WebConfigurationProperty -pspath 'MACHINE/WEBROOT/APPHOST/<website name>'
-filter "system.webServer/httpErrors" -name "errorMode"
```

Remediation:

The following describes how to change the `errorMode` attribute to `DetailedLocalOnly` or `Custom` for a Web site by using IIS Manager:

1. Open IIS Manager with Administrative privileges
2. In the Connections pane on the left, expand the server, then expand the Sites folder
3. Select the Web site or application to be configured
4. In Features View, select Error Pages, in the Actions pane, select Open Feature
5. In the Actions pane, select Edit Feature Settings
6. In the Edit Error Pages Settings dialog, under Error Responses, select either Custom error pages or Detailed errors for local requests and custom error pages for remote requests
7. Click OK and exit the Edit Error Pages Settings dialog

OR

Enter the following command in PowerShell to configure:

```
Set-WebConfigurationProperty -pspath 'MACHINE/WEBROOT/APPHOST/<website name>'
-filter "system.webServer/httpErrors" -name "errorMode" -value
"DetailedLocalOnly"
```

Default Value:

The default `errorMode` is `DetailedLocalOnly`.

References:

1. <http://technet.microsoft.com/en-us/library/dd391900%28WS.10%29.aspx>
2. <http://www.iis.net/configreference/system.webserver/httperrors>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v7	18 <u>Application Software Security</u> Application Software Security			

3.5 (L2) Ensure ASP.NET stack tracing is not enabled (Automated)

Profile Applicability:

- Level 2 - IIS 10

Description:

The `trace` element configures the ASP.NET code tracing service that controls how trace results are gathered, stored, and displayed. When tracing is enabled, each page request generates trace messages that can be appended to the page output or stored in an application trace log.

This is a defense in depth recommendation due to the `<deployment retail="true" />` in the `machine.config` file overriding any settings for ASP.NET stack tracing that are left on.

It is recommended that ASP.NET stack tracing still be turned off.

Rationale:

In an active Web Site, tracing should not be enabled because it can display sensitive configuration and detailed stack trace information to anyone who views the pages in the site.

If necessary, the `localOnly` attribute can be set to true to have trace information displayed only for localhost requests. Ensuring that ASP.NET stack tracing is not on will help mitigate the risk of malicious persons learning detailed stack trace information.

Impact:

ASP.NET stack tracing still be turned off and sensitive configuration and detailed stack trace information will not be viewable to anyone who views the pages in the site.

Audit:

Tracing is configurable at numerous levels:

1. Machine.config
2. Root-level web.config
3. Application-level web.config
4. Virtual or physical directory-level web.config
5. Individual ASP.Net page level

Verify ASP.NET tracing is not turned on, via a per-page basis in the application.
Ensure the trace attribute is not enabled:

```
Trace="true"
```

On an application basis like in the `web.config` ensure that tracing is not enabled like:

```
<configuration>
  <system.web>
    <trace enabled="true">
  </system.web>
</configuration>
```

OR

To verify using PowerShell enter the following command:

```
Get-WebConfigurationProperty -pspath 'MACHINE/WEBROOT/APPHOST/<website name>'
-filter "system.web/trace" -name "enabled" | Format-List Name,Value
```


Remediation:

1. Ensure `<deployment retail="true" />` is enabled in the `machine.config`.
2. Remove all attribute references to ASP.NET tracing by deleting the trace and trace enable attributes.

Per Page:

Remove any references to:

```
Trace="true"
```

Per Application:

```
<configuration>
  <system.web>
    <trace enabled="true">
  </system.web>
</configuration>
```

OR

Enter the following command in PowerShell to configure:

```
Set-WebConfigurationProperty -pspath 'MACHINE/WEBROOT/APPHOST/<website name>'
-filter "system.web/trace" -name "enabled" -value "False"
```

Default Value:

The default value for ASP.NET tracing is off.

References:

1. <http://msdn.microsoft.com/en-us/library/94c55d08%28v=vs.100%29.aspx>
2. <http://msdn.microsoft.com/en-us/library/0x5wc973%28v=vs.100%29.aspx>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v7	18 <u>Application Software Security</u> Application Software Security			

3.6 (L2) Ensure 'httpcookie' mode is configured for session state (Automated)

Profile Applicability:

- Level 2 - IIS 10

Description:

A session cookie associates session information with client information for that session, which can be the duration of a user's connection to a site. The cookie is passed in a HTTP header together with all requests between the client and server.

Session information can also be stored in the URL. However, storing session information in this manner has security implications that can open attack vectors such as session hijacking. An effective method used to prevent session hijacking attacks is to force web applications to use cookies to store the session token. This is accomplished by setting the `cookieless` attribute of the `sessionState` node to `UseCookies` or `False` which will in turn keep session state data out of URI.

It is recommended that session state be configured to `UseCookies`.

Rationale:

Cookies that have been properly configured help mitigate the risk of attacks such as session hi-jacking attempts by preventing ASP.NET from having to move session information to the URL; moving session information in URI causes session IDs to show up in proxy logs and is accessible to client scripting via `document.location`.

Impact:

Session information in URI session IDs will not show up in proxy logs.

Audit:

Find and open the `web.config` file for the application/site and verify that the `sessionState` tag is set to use cookies:

```
<system.web>
  <sessionState cookieless="UseCookies" />
</system.web>
```

OR

To verify using PowerShell enter the following command:

```
Get-WebConfigurationProperty -pspath 'MACHINE/WEBROOT/APPHOST/<website name>'
-filter "system.web/sessionState" -name "mode"
```

Remediation:

`SessionState` can be set to `UseCookies` by using the IIS Manager GUI, using `AppCmd.exe` commands in a command-line window, directly editing the configuration files, or by writing WMI scripts. Perform the following to set the `cookieless` attribute of the `sessionState` node to `UseCookies` in the IIS Manager GUI:

1. Open the IIS Manager GUI and navigate desired server, site, or application
2. In Features View, find and double-click the Session State icon
3. In the Cookie Settings section, choose Use Cookies from the Mode dropdown
4. In the Actions Pane, click Apply

To use `AppCmd.exe` to configure `sessionState` at the server level, the command would look like this:

```
%systemroot%\system32\inetsrv\appcmd set config /commit:WEBROOT
/section:sessionState /cookieless:UseCookies /cookieName:ASP.NET_SessionID
/timeout:20
```

When `Appcmd.exe` is used to configure the `<sessionstate>` element at the global level in IIS, the `/commit:WEBROOT` switch must be included so that configuration changes are made to the root `web.config` file instead of `ApplicationHost.config`.

OR

Enter the following command in PowerShell to configure:

```
Set-WebConfigurationProperty -pspath 'MACHINE/WEBROOT/APPHOST/<website name>'
-filter "system.web/sessionState" -name "mode" -value "StateServer"
```

Default Value:

By default, IIS maintains session state data for a managed code application in the worker process where the application runs e.g. In Process.

References:

1. <http://www.iis.net/learn/application-frameworks/scenario-build-an-aspnet-website-on-iis/planning-step-2-plan-asp-net-settings>
2. <http://msdn.microsoft.com/en-us/library/h6bb9cz9%28VS.71%29.aspx>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v7	18 <u>Application Software Security</u> Application Software Security			

3.7 (L1) Ensure 'cookies' are set with *HttpOnly* attribute (Automated)

Profile Applicability:

- Level 1 - IIS 10

Description:

The `httpOnlyCookies` attribute of the `httpCookies` node determines if IIS will set the `HttpOnly` flag on HTTP cookies it sets. The `HttpOnly` flag indicates to the user agent that the cookie must not be accessible by client-side script (i.e `document.cookie`).

It is recommended that the `httpOnlyCookies` attribute be set to `true`.

Rationale:

When cookies are set with the `HttpOnly` flag, they cannot be accessed by client-side scripting running in the user's browser. Preventing client-side scripting from accessing cookie content may reduce the probability of a cross site scripting attack materializing into a successful session hijack.

Impact:

N/A

Audit:

After the next time IIS is restarted, browse to and open the `web.config` for the application in which `httpOnly` cookies have been turned on. Confirm the `httpOnlyCookies` attribute is set to `true`: `<httpCookies httpOnlyCookies="true" />`.

Remediation:

1. Locate and open the application's `web.config` file
2. Add the `<httpCookies httpOnlyCookies="true" />` tag within `<system.web>`:

```
<configuration>
  <system.web>
    <httpCookies httpOnlyCookies="true" />
  </system.web>
</configuration>
```

Setting the value of the `httpOnlyCookies` attribute of the `httpCookies` element to `true` will add the `HttpOnly` flag to all the cookies set by the application. All modern versions of browsers recognize `HttpOnly` attribute; older versions will either treat them as normal cookies or simply ignore them altogether.

Default Value:

By default, ASP.NET 2.0 does not force cookies to `httpOnly`.

References:

1. <https://tools.ietf.org/wg/httpstate/charters>
2. https://www.owasp.org/index.php/HTTPOnly#Browsers_Supporting_HttpOnly
3. <https://msdn.microsoft.com/en-us/library/ms533046.aspx>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v7	18 <u>Application Software Security</u> Application Software Security			

3.8 (L2) Ensure 'MachineKey validation method - .Net 3.5' is configured (Automated)

Profile Applicability:

- Level 2 - IIS 10

Description:

The `machineKey` element of the ASP.NET `web.config` specifies the algorithm and keys that ASP.NET will use for encryption. The Machine Key feature can be managed to specify hashing and encryption settings for application services such as view state, Forms authentication, membership and roles, and anonymous identification.

The following validation methods are available:

- Advanced Encryption Standard (AES) is relatively easy to implement and requires little memory. AES has a key size of 128, 192, or 256 bits. This method uses the same private key to encrypt and decrypt data, whereas a public-key method must use a pair of keys
- Message Digest 5 (MD5) is used for digital signing of applications. This method produces a 128-bit message digest, which is a compressed form of the original data
- Secure Hash Algorithm (SHA1) is considered more secure than MD5 because it produces a 160-bit message digest
- Triple Data Encryption Standard (TripleDES) is a minor variation of Data Encryption Standard (DES). It is three times slower than regular DES but can be more secure because it has a key size of 192 bits. If performance is not a primary consideration, consider using TripleDES

It is recommended that AES or SHA1 methods be configured for use at the global level.

Rationale:

Setting the validation property to AES will provide confidentiality and integrity protection to the viewstate. AES is the strongest encryption algorithm supported by the validation property. Setting the validation property to SHA1 will provide integrity protection to the viewstate. SHA1 is the strongest hashing algorithm supported by the validation property.

Impact:

N/A

Audit:

To verify the Machine Key validation method using IIS Manager:

1. Open IIS Manager and navigate to the level that was configured, the WEBROOT, or server in this case
2. In the features view, double click Machine Key
3. On the Machine Key page, verify that SHA1 is selected in the validation method dropdown

Remediation:

Machine key encryption can be set by using the UI, running `appcmd.exe` commands, by editing configuration files directly, or by writing WMI scripts. To set the Machine Key encryption at the global level using an `appcmd.exe` command:

```
%systemroot%\system32\inetsrv\appcmd set config /commit:WEBROOT  
/section:machineKey /validation:SHA1
```

Note: When `Appcmd.exe` is used to configure the `<machineKey>` element at the global level in IIS, the `/commit:WEBROOT` switch must be included so that configuration changes are made to the root `web.config` file instead of `ApplicationHost.config`.

Default Value:

The default Machine Key validation method is SHA1.

References:

1. <http://technet.microsoft.com/en-us/library/cc772271%28WS.10%29.aspx>
2. <http://technet.microsoft.com/en-us/library/cc772287%28WS.10%29.aspx>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.10 <u>Encrypt Sensitive Data in Transit</u> Encrypt sensitive data in transit. Example implementations can include: Transport Layer Security (TLS) and Open Secure Shell (OpenSSH).			
v7	14.4 <u>Encrypt All Sensitive Information in Transit</u> Encrypt all sensitive information in transit.			

3.9 (L1) Ensure 'MachineKey validation method - .Net 4.5' is configured (Automated)

Profile Applicability:

- Level 1 - IIS 10

Description:

The `machineKey` element of the ASP.NET `web.config` specifies the algorithm and keys that ASP.NET will use for encryption. The Machine Key feature can be managed to specify hashing and encryption settings for application services such as view state, Forms authentication, membership and roles, and anonymous identification.

The following validation methods are available:

- Advanced Encryption Standard (AES) is relatively easy to implement and requires little memory. AES has a key size of 128, 192, or 256 bits. This method uses the same private key to encrypt and decrypt data, whereas a public-key method must use a pair of keys
- Message Digest 5 (MD5) is used for digital signing of applications. This method produces a 128-bit message digest, which is a compressed form of the original data
- Secure Hash Algorithm (SHA1) is considered more secure than MD5 because it produces a 160-bit message digest
- Triple Data Encryption Standard (TripleDES) is a minor variation of Data Encryption Standard (DES). It is three times slower than regular DES but can be more secure because it has a key size of 192 bits. If performance is not a primary consideration, consider using TripleDES
- Secure Hash Algorithm (SHA-2) is a family of two similar hash functions, with different block sizes known as SHA-256 and SHA-512. They differ in the word size; SHA-256 used 32-bit words and SHA-512 uses 64-bit words.

It is recommended that SHA-2 methods be configured for use at the global level.

Rationale:

SHA-2 is the strongest hashing algorithm supported by the validation property so it should be used as the validation method for the MachineKey in .Net 4.5.

Impact:

N/A

Audit:

To verify the Machine Key validation method using IIS Manager:

1. Open IIS Manager and navigate to the level that was configured, the WEBROOT, or server in this case
2. In the features view, double click Machine Key
3. On the Machine Key page, verify that HMACSHA256 is selected in the validation method dropdown

OR

To verify using PowerShell enter the following command:

```
Get-WebConfigurationProperty -pspath 'MACHINE/WEBROOT' -filter  
"system.web/machineKey" -name "validation"
```

Remediation:

Machine key encryption can be set by using the UI, running `appcmd.exe` commands, by editing configuration files directly, or by writing WMI scripts. To set the Machine Key encryption at the global level using an `appcmd.exe` command:

```
%systemroot%\system32\inetsrv\appcmd set config /commit:WEBROOT  
/section:machineKey /validation:<validation method>
```

Note: When `Appcmd.exe` is used to configure the `<machineKey>` element at the global level in IIS, the `/commit:WEBROOT` switch must be included so that configuration changes are made to the root `web.config` file instead of `ApplicationHost.config`.

OR

Enter the following command in PowerShell to configure:

```
Set-WebConfigurationProperty -pspath 'MACHINE/WEBROOT' -filter  
"system.web/machineKey" -name "validation" -value "<validation method>"
```

Default Value:

The default Machine Key validation method is SHA256.

References:

1. <http://www.iis.net/learn/get-started/whats-new-in-iis-8/iis-80-aspnet-configuration-management>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.10 <u>Encrypt Sensitive Data in Transit</u> Encrypt sensitive data in transit. Example implementations can include: Transport Layer Security (TLS) and Open Secure Shell (OpenSSH).			
v7	14.4 <u>Encrypt All Sensitive Information in Transit</u> Encrypt all sensitive information in transit.			

3.10 (L1) Ensure global .NET trust level is configured (Automated)

Profile Applicability:

- Level 1 - IIS 10

Description:

An application's trust level determines the permissions that are granted by the ASP.NET code access security (CAS) policy. CAS defines two trust categories: full trust and partial trust. An application that has full trust permissions may access all resource types on a server and perform privileged operations, while applications that run with partial trust have varying levels of operating permissions and access to resources.

The possible values for the Level property of the TrustSection class are:

- Full: Specifies unrestricted permissions and grants the ASP.NET application permissions to access any resource that is subject to operating system security; all privileged operations are supported
- High: specifies a high level of code access security which limits the application from doing the following:
 - Call unmanaged code
 - Call serviced components
 - Write to the event log
 - Access Microsoft Windows Message Queuing queues
 - Access ODBC, OLD DB, or Oracle data sources
- Medium: specifies a medium level of code access security, which means that in addition to the restrictions for High, the ASP.NET application cannot do any of the following things:
 - Access files outside the application directory
 - Access the registry
- Low: specifies a low level of code access security, which means that in addition to the restrictions for Medium, the application is prevented from performing any of the following actions:
 - Write to the file system
 - Call the `System.Security.CodeAccessPermission.Assert` method to expand permissions to resources
 - Minimal: specifies a minimal level of code access security, which means that the application has only execute permission

It is recommended that the global .NET Trust Level be set to Medium or lower.

Rationale:

The CAS determines the permissions that are granted to the application on the server. Setting a minimal level of trust that is compatible with the applications will limit the potential harm that a compromised application could cause to a system.

Impact:

If not set properly, the application may not run.

Audit:

To verify the global .NET Trust Level using IIS Manager:

1. Open IIS Manager and navigate to the level that was configured, the server in this example
2. In the features view, double click .NET Trust Levels
3. On the .NET Trust Levels page, verify that `Medium (web_mediumtrust.config)` is selected in the Trust Level dropdown

OR

To verify using PowerShell enter the following command:

```
Get-WebConfigurationProperty -pspath 'MACHINE/WEBROOT' -filter  
"system.web/trust" -name "level"
```

Remediation:

Trust level can be set by using the UI, running `appcmd.exe` commands, by editing configuration files directly, or by writing WMI scripts. To set the .Net Trust Level to Medium at the server level using an `appcmd.exe` command:

```
%systemroot%\system32\inetsrv\appcmd set config /commit:WEBROOT  
/section:trust /level:Medium
```

When `Appcmd.exe` is used to configure the element at the global level in IIS, the `/commit:WEBROOT` switch must be included so that configuration changes are made to the root `web.config` file instead of `ApplicationHost.config`.

OR

Enter the following command in PowerShell to configure:

```
Set-WebConfigurationProperty -pspath 'MACHINE/WEBROOT' -filter  
"system.web/trust" -name "level" -value "Medium"
```

Default Value:

By default, ASP.NET web applications run under the full trust setting.

References:

1. [http://technet.microsoft.com/en-us/library/cc772237\(WS.10\).aspx](http://technet.microsoft.com/en-us/library/cc772237(WS.10).aspx)
2. <http://msdn.microsoft.com/en-us/library/ms691448%28VS.90%29.aspx>
3. <http://support.microsoft.com/kb/2698981>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.3 <u>Configure Data Access Control Lists</u> Configure data access control lists based on a user's need to know. Apply data access control lists, also known as access permissions, to local and remote file systems, databases, and applications.			
v7	14.6 <u>Protect Information through Access Control Lists</u> Protect all information stored on systems with file system, network share, claims, application, or database specific access control lists. These controls will enforce the principle that only authorized individuals should have access to the information based on their need to access the information as a part of their responsibilities.			

3.11 (L2) Ensure X-Powered-By Header is removed (Manual)

Profile Applicability:

- Level 2 - IIS 10

Description:

The x-powered-by headers specify the underlying technology used by the webserver.

Rationale:

Attackers are able to conduct reconnaissance on a website using these response headers. This header could be used to target attacks for specific known vulnerabilities associated with the underlying technology. Removing this header will prevent targeting of your application for specific exploits by non-determined attackers.

While this is not the only way to fingerprint a site through the response headers, it makes it harder and prevents some potential attackers.

Impact:

X-powered-by headers will not be available on the webserver.

Audit:

To verify using AppCmd.exe enter the following command:

```
%systemroot%\system32\inetsrv\appcmd.exe list config -  
section:system.webServer/httpProtocol
```

Remediation:

Enter the following command in AppCmd.exe to configure:

```
%systemroot%\system32\inetsrv\appcmd.exe set config -  
section:system.webServer/httpProtocol /- "customHeaders.[name='X-Powered-By']"  
/commit:apphost
```

OR

Enter the following command in PowerShell to configure:

```
Remove-WebConfigurationProperty -pspath 'MACHINE/WEBROOT/APPHOST' -filter  
"system.webserver/httpProtocol/customHeaders" -name "." -AtElement @{name='X-  
Powered-By'}
```

References:

1. <https://blogs.msdn.microsoft.com/jpsanders/2015/10/07/remove-server-and-x-powered-by-headers-from-your-azure-mobile-apps/>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	<u>4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software</u> Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.			

3.12 (L2) Ensure Server Header is removed (Manual)

Profile Applicability:

- Level 2 - IIS 10

Description:

The server header headers specify the underlying technology used by the application.

Rationale:

While this is not the only way to fingerprint a site through the response headers, it makes it harder and prevents some potential attackers. The server header removal directive is a new feature in IIS 10 that can assist in mitigating this risk.

Impact:

This will remove the server header.

Audit:

To verify using AppCmd.exe enter the following command:

```
%systemroot%\system32\inetsrv\appcmd.exe list config -  
section:system.webServer/security/requestFiltering
```

OR

To verify using PowerShell enter the following command:

```
Get-WebConfigurationProperty -pspath machine/webroot/apphost -filter  
'system.webserver/security/requestfiltering  
' -name 'removeServerHeader'
```

Remediation:

Enter the following command to use AppCmd.exe to configure:

```
%systemroot%\system32\inetsrv\appcmd.exe set config -  
section:system.webServer/security/requestFiltering /removeServerHeader:"True"  
/commit:apphost
```

OR

Enter the following command in PowerShell to configure:

```
Set-WebConfigurationProperty -pspath 'MACHINE/WEBROOT/APPHOST/' -filter  
"system.webServer/security/requestFiltering" -name "removeServerHeader" -  
value "True"
```

Default Value:

Microsoft-IIS/10.0

References:

1. <https://blogs.msdn.microsoft.com/jpsanders/2015/10/07/remove-server-and-x-powered-by-headers-from-your-azure-mobile-apps/>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.8 <u>Uninstall or Disable Unnecessary Services on Enterprise Assets and Software</u> Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.		●	●

4 Request Filtering and Other Restriction Modules

Introduced in IIS 7.0 for the first time, Request Filtering is a powerful module that provides a configurable set of rules that enables administrators to allow or reject the types of requests that they determine should be allowed or rejected at the server, web site, or web application levels.

Earlier versions of Internet Information Services provided the tool UrlScan, which was provided as an add-on to enable system administrators to enforce tighter security policies on their web servers. All of the core features of URLScan have been incorporated into the Request Filtering module. Due to the close nature of functionality in these two tools, reference to legacy URLScan settings will be made where applicable.

IIS 8 also introduced modules for Dynamic IP Address Restrictions. This module can be configured to automatically block web site access based on specific rules.

Note: Request Filtering and IP and Domain Restrictions must be enabled as a role service under IIS in order to configure any of its features.

4.1 (L2) Ensure 'maxAllowedContentLength' is configured (Manual)

Profile Applicability:

- Level 2 - IIS 10

Description:

The `maxAllowedContentLength` Request Filter is the maximum size of the http request, measured in bytes, which can be sent from a client to the server. Configuring this value enables the total request size to be restricted to a configured value.

It is recommended that the overall size of requests be restricted to a maximum value appropriate for the server, site, or application.

Rationale:

Setting an appropriate value that has been tested for the `maxAllowedContentLength` filter will lower the impact an abnormally large request would otherwise have on IIS and/or web applications. This helps to ensure availability of web content and services, and may also help mitigate the risk of buffer overflow type attacks in unmanaged components.

Impact:

Size of requests be restricted to the maximum value set.

Audit:

Upon exceeding the configured value set for the Request Filter, IIS will throw a Status Code 404.13.

To manually verify the change, locate and open the `web.config` for the web site or application in which the request filter was set. Ensure the value defined for `maxAllowedContentLength` is what was set. The 28.6MB max example would show:

```
<configuration>
  <system.webServer>
    <security>
      <requestFiltering>
        <requestLimits
          maxAllowedContentLength="30000000" />
        </requestFiltering>
      </security>
    </system.webServer>
  </configuration>
```

OR

To verify using PowerShell enter the following command:

```
Get-WebConfigurationProperty -pspath 'MACHINE/WEBROOT/APPHOST' -filter
"system.webServer/security/requestFiltering/requestLimits" -name
"maxAllowedContentLength"
```

Remediation:

The `MaxAllowedContentLength` Request Filter may be set for a server, website, or application using the IIS Manager GUI, using `AppCmd.exe` commands in a command-line window, and/or directly editing the configuration files. To configure using the IIS Manager GUI:

1. Open Internet Information Services (IIS) Manager
2. In the Connections pane, click on the server, site, application, or directory to be configured
3. In the Home pane, double-click Request Filtering
4. Click Edit Feature Settings... in the Actions pane
5. Under the Request Limits section, key the maximum content length in bytes that will allow applications to retain their intended functionality, such as 30000000 (approx. 28.6 MB)

Enter the following command in `AppCmd.exe` to configure:

```
%systemroot%\system32\inetsrv\appcmd set config /section:requestfiltering  
/requestLimits.maxAllowedContentLength:30000000
```

OR

Enter the following command in PowerShell to configure:

```
Set-WebConfigurationProperty -pspath 'MACHINE/WEBROOT/APPHOST' -filter  
"system.webServer/security/requestFiltering/requestLimits" -name  
"maxAllowedContentLength" -value 30000000
```

Default Value:

When request filtering is installed on a system, the default value is:

`maxAllowedContentLength="30000000"`, which is approximately 28.6MB.

References:

1. <http://www.iis.net/ConfigReference/system.webServer/security/requestFiltering/requestLimits>
2. <http://learn.iis.net/page.aspx/143/use-request-filtering/>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v7	18 <u>Application Software Security</u> Application Software Security			

4.2 (L2) Ensure 'maxURL request filter' is configured (Automated)

Profile Applicability:

- Level 2 - IIS 10

Description:

The `maxURL` attribute of the `<requestLimits>` property is the maximum length (in Bytes) in which a requested URL can be (excluding query string) in order for IIS to accept. Configuring this Request Filter enables administrators to restrict the length of the requests that the server will accept.

It is recommended that a limit be put on the length of URL.

Rationale:

With a properly configured Request Filter limiting the amount of data accepted in the URL, chances of undesired application behaviors affecting the availability of content and services are reduced.

Impact:

Length of the URL will be restricted to the maximum value set.

Audit:

IIS will log a 404.14 HTTP status if the requested URL was rejected because it exceeded the length defined in the filter.

To manually verify the change, locate and open the `web.config` for the web site or application in which the request filter was set. Verify the value defined for `maxURL`.

```
<configuration>
  <system.webServer>
    <security>
      <requestFiltering>
        <requestLimits
          maxURL="4096" />
        </requestFiltering>
      </security>
    </system.webServer>
  </configuration>
```

OR

To verify using PowerShell enter the following command:

```
Get-WebConfigurationProperty -pspath 'MACHINE/WEBROOT/APPHOST' -filter
"system.webServer/security/requestFiltering/requestLimits" -name "maxUrl"
```


Remediation:

The `MaxURL` Request Filter may be set for a server, website, or application using the IIS Manager GUI, using `AppCmd.exe` commands in a command-line window, and/or directly editing the configuration files. To configure using the IIS Manager GUI:

1. Open Internet Information Services (IIS) Manager
2. In the Connections pane, click on the connection, site, application, or directory to be configured
3. In the Home pane, double-click Request Filtering
4. Click Edit Feature Settings... in the Actions pane
5. Under the Request Limits section, key the maximum URL length in bytes that has been tested with web applications

Enter the following command in `AppCmd.exe` to configure:

```
%systemroot%\system32\inetsrv\appcmd set config /section:requestfiltering  
/requestLimits.maxURL:4096
```

OR

Enter the following command in PowerShell to configure:

```
Set-WebConfigurationProperty -pspath 'MACHINE/WEBROOT/APPHOST' -filter  
"system.webServer/security/requestFiltering/requestLimits" -name "maxUrl" -  
value 4096
```

Default Value:

When Request Filtering is installed on a system, the default value for `maxURL`="4096".

References:

1. <http://www.iis.net/ConfigReference/system.webServer/security/requestFiltering/requestLimits>
2. <http://learn.iis.net/page.aspx/143/use-request-filtering/>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v7	18 <u>Application Software Security</u> Application Software Security			

4.3 (L2) Ensure 'MaxQueryString request filter' is configured (Automated)

Profile Applicability:

- Level 2 - IIS 10

Description:

The `MaxQueryString` Request Filter describes the upper limit on the length of the query string that the configured IIS server will allow for websites or applications.

It is recommended that values always be established to limit the amount of data that can be accepted in the query string.

Rationale:

With a properly configured Request Filter limiting the amount of data accepted in the query string, chances of undesired application behaviors such as app pool failures are reduced.

Impact:

The amount of data to be accepted in the query string will be limited.

Audit:

If a request is rejected because it exceeds the value set in the `maxQueryString` Request Filter, a 404.15 HTTP status is logged to the IIS log file.

To manually verify the change, locate and open the `web.config` for the web site or application in which the filter was set. Ensure the value defined for `maxQueryString` is what was configured.

```
<configuration>
  <system.webServer>
    <security>
      <requestFiltering>
        <requestLimits
          maxQueryString="2048" />
        </requestFiltering>
      </security>
    </system.webServer>
  </configuration>
```

OR

To verify using PowerShell enter the following command:

```
Get-WebConfigurationProperty -pspath 'MACHINE/WEBROOT/APPHOST' -filter
"system.webServer/security/requestFiltering/requestLimits" -name
"maxQueryString"
```

Remediation:

The `MaxQueryString` Request Filter may be set for a server, website, or application using the IIS Manager GUI, using `AppCmd.exe` commands in a command-line window, and/or directly editing the configuration files. To configure using the IIS Manager GUI:

1. Open Internet Information Services (IIS) Manager
2. In the Connections pane, go to the connection, site, application, or directory to be configured
3. In the Home pane, double-click Request Filtering
4. Click Edit Feature Settings... in the Actions pane
5. Under the Request Limits section, key in a safe upper bound in the Maximum query string (Bytes) textbox

Enter the following command in `AppCmd.exe` to configure:

```
%systemroot%\system32\inetsrv\appcmd set config /section:requestfiltering  
/requestLimits.maxQueryString:2048
```

OR

Enter the following command in PowerShell to configure:

```
Set-WebConfigurationProperty -pspath 'MACHINE/WEBROOT/APPHOST' -filter  
"system.webServer/security/requestFiltering/requestLimits" -name  
"maxQueryString" -value 2048
```

Default Value:

When request filtering is installed on a system, the default value is
`maxQueryString="2048"`.

References:

1. <http://www.iis.net/ConfigReference/system.webServer/security/requestFiltering/requestLimits>
2. <http://learn.iis.net/page.aspx/143/use-request-filtering/>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v7	<u>18 Application Software Security</u> Application Software Security			

4.4 (L2) Ensure non-ASCII characters in URLs are not allowed (Automated)

Profile Applicability:

- Level 2 - IIS 10

Description:

This feature is used to allow or reject all requests to IIS that contain non-ASCII characters. When using this feature, Request Filtering will deny the request if high-bit characters are present in the URL. The UrlScan equivalent is `AllowHighBitCharacters`.

It is recommended that requests containing non-ASCII characters be rejected, where possible.

Rationale:

This feature can help defend against canonicalization attacks, reducing the potential attack surface of servers, sites, and/or applications.

Impact:

Requests containing non-ASCII characters be rejected.

Audit:

If a request is rejected because it contains a high-bit character, a 404.12 HTTP status is logged to the IIS log file.

To manually verify the change, locate and open the `web.config` for the web site or application in which the request filter was set. Ensure the value defined for the filter is false, as such:

```
<configuration>
  <system.webServer>
    <security>
      <requestFiltering
        allowHighBitCharacters="false">
      </requestFiltering>
    </security>
  </system.webServer>
</configuration>
```

OR

To verify using PowerShell enter the following command:

```
Get-WebConfigurationProperty -pspath 'MACHINE/WEBROOT/APPHOST' -filter
'system.webServer/security/requestFiltering' -name 'allowHighBitCharacters'
```

Remediation:

The `AllowHighBitCharacters` Request Filter may be set for a server, website, or application using the IIS Manager GUI, using `AppCmd.exe` commands in a command-line window, and/or directly editing the configuration files. To configure using the IIS Manager GUI:

1. Open Internet Information Services (IIS) Manager
2. In the Connections pane, go to the connection, site, application, or directory to be configured
3. In the Home pane, double-click Request Filtering
4. Click Edit Feature Settings... in the Actions pane
5. Under the General section, uncheck Allow high-bit characters

Note: Disallowing high-bit ASCII characters in the URL may negatively impact the functionality of sites requiring international language support.

Enter the following command in `AppCmd.exe` to configure:

```
%systemroot%\system32\inetsrv\appcmd set config /section:requestfiltering  
/allowHighBitCharacters:false
```

OR

Enter the following command in PowerShell to configure:

```
Set-WebConfigurationProperty -pspath 'MACHINE/WEBROOT/APPHOST' -filter  
"system.webServer/security/requestFiltering" -name "allowHighBitCharacters" -  
value "False"
```

Default Value:

When Request Filtering is installed on a system, the default behavior is to allow high-bit characters in URI.

References:

1. <http://learn.iis.net/page.aspx/143/use-request-filtering/>
2. <http://learn.iis.net/page.aspx/936/urlscan-1-reference/>
3. Professional IIS 7 by Ken Schaefer, Jeff Cochran, Scott Forsyth, Rob Baugh, Mike Everest, Dennis Glendenning

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v7	18 <u>Application Software Security</u> Application Software Security			

4.5 (L1) Ensure Double-Encoded requests will be rejected (Automated)

Profile Applicability:

- Level 1 - IIS 10

Description:

This Request Filter feature prevents attacks that rely on double-encoded requests and applies if an attacker submits a double-encoded request to IIS. When the double-encoded requests filter is enabled, IIS will go through a two iteration process of normalizing the request. If the first normalization differs from the second, the request is rejected and the error code is logged as a 404.11. The double-encoded requests filter was the `VerifyNormalization` option in `UrlScan`.

It is recommended that double-encoded requests be rejected.

Rationale:

This feature will help prevent attacks that rely on URLs that have been crafted to contain double-encoded request(s).

Impact:

Double-encoded requests will be rejected.

Audit:

If a request is rejected because it contains a double-encoded request, a 404.11 HTTP status is logged to the IIS log file.

To manually verify the change, locate and open the `web.config` for the web site or application in which the request filter was set. Ensure the value defined for `allowDoubleEscaping` is `false`:

```
<configuration>
  <system.webServer>
    <security>
      <requestFiltering
        allowDoubleEscaping="false">
      </requestFiltering>
    </security>
  </system.webServer>
</configuration>
```

OR

To verify using PowerShell enter the following command:

```
Get-WebConfigurationProperty -pspath 'MACHINE/WEBROOT/APPHOST' -filter
"system.webServer/security/requestFiltering" -name "allowDoubleEscaping"
```

Remediation:

The `allowDoubleEscaping` Request Filter may be set for a server, website, or application using the IIS Manager GUI, using `AppCmd.exe` commands in a command-line window, and/or directly editing the configuration files. To configure using the IIS Manager GUI:

1. Open Internet Information Services (IIS) Manager
2. In the Connections pane, select the site, application, or directory to be configured
3. In the Home pane, double-click Request Filtering
4. Click Edit Feature Settings... in the Actions pane
5. Under the General section, uncheck Allow double escaping

If a file name in a URL includes "+" then `allowDoubleEscaping` must be set to `true` to allow functionality.

Enter the following command in `AppCmd.exe` to configure:

```
%systemroot%\system32\inetsrv\appcmd set config /section:requestfiltering  
/allowDoubleEscaping:false
```

OR

Enter the following command in PowerShell to configure:

```
Set-WebConfigurationProperty -pspath 'MACHINE/WEBROOT/APPHOST' -filter  
"system.webServer/security/requestFiltering" -name "allowDoubleEscaping" -  
value "True"
```

Default Value:

When Request Filtering is installed on a system, the default behavior is to not allow double-encoded requests.

References:

1. <http://www.iis.net/ConfigReference/system.webServer/security/requestFiltering/requestLimits>
2. <http://learn.iis.net/page.aspx/143/use-request-filtering/>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	10.5 <u>Enable Anti-Exploitation Features</u> Enable anti-exploitation features on enterprise assets and software, where possible, such as Microsoft® Data Execution Prevention (DEP), Windows® Defender Exploit Guard (WDEG), or Apple® System Integrity Protection (SIP) and Gatekeeper™.		●	●
v7	18 <u>Application Software Security</u> Application Software Security			

4.6 (L1) Ensure 'HTTP Trace Method' is disabled (Manual)

Profile Applicability:

- Level 1 - IIS 10

Description:

The HTTP TRACE method returns the contents of client HTTP requests in the entity-body of the TRACE response. Attackers could leverage this behavior to access sensitive information, such as authentication data or cookies, contained in the HTTP headers of the request. One such way to mitigate this is by using the `<verbs>` element of the `<requestFiltering>` collection. The `<verbs>` element replaces the `[AllowVerbs]` and `[DenyVerbs]` features in UrlScan.

It is recommended the HTTP TRACE method be denied.

Rationale:

Attackers may abuse HTTP TRACE functionality to gain access to information in HTTP headers such as cookies and authentication data. This risk can be mitigated by not allowing the TRACE verb.

Impact:

Contents of client HTTP requests in the entity-body of the TRACE response will not be available.

Audit:

IIS will return an HTTP 404.6 error to the client when Request Filtering blocks an HTTP request because of a denied HTTP verb. To manually verify the change, browse to the `web.config` file for which the change was made and verify the below configuration:

```
<configuration>
  <system.webServer>
    <security>
      <requestFiltering>
        <verbs>
          <add verb="TRACE" allowed="false" />
        </verbs>
      </requestFiltering>
    </security>
  </system.webServer>
</configuration>
```

To view this Request Filter using an `AppCmd.exe` command, run the following command at an elevated command prompt:

```
%systemroot%\system32\inetsrv\appcmd listconfig /section:requestfiltering
```

Remediation:

1. Open Internet Information Services (IIS) Manager
2. In the Connections pane, select the site, application, or directory to be configured
3. In the Home pane, double-click Request Filtering
4. In the Request Filtering pane, click the HTTP verbs tab, and then click Deny Verb... in the Actions pane
5. In the Deny Verb dialog box, enter the TRACE, and then click OK

Enter the following command in `AppCmd.exe` to configure:

```
%systemroot%\system32\inetsrv\appcmd set config /section:requestfiltering
/verbs.[verb='TRACE',allowed='false']
```

OR

Enter the following command in PowerShell to configure:

```
Add-WebConfigurationProperty -pspath 'MACHINE/WEBROOT/APPHOST' -filter
"system.webServer/security/requestFiltering/verbs" -name "." -value
@{verb='TRACE';allowed='False'}
```

Default Value:

The TRACE verb is not filtered by default.

References:

1. <http://www.kb.cert.org/vuls/id/867593>
2. <http://www.iis.net/ConfigReference/system.webServer/security/requestFiltering/verbs>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v7	18 <u>Application Software Security</u> Application Software Security			

4.7 (L1) Ensure Unlisted File Extensions are not allowed (Automated)

Profile Applicability:

- Level 1 - IIS 10

Description:

The `FileExtensions` Request Filter allows administrators to define specific extensions their web server(s) will allow and disallow. The property `allowUnlisted` will cover all other file extensions not explicitly allowed or denied. Often times, extensions such as `.config`, `.bat`, `.exe`, to name a few, should never be served. The `AllowExtensions` and `DenyExtensions` options are the `UrlScan` equivalents.

It is recommended that all extensions be disallowed at the most global level possible, with only those necessary being allowed.

Rationale:

Disallowing all but the necessary file extensions can greatly reduce the attack surface of applications and servers.

Impact:

If not set properly, file extensions that are needed will be rejected.

Audit:

When IIS rejects a request based on a file extensions filter, the error code logged is 404.7.

To manually verify the change, locate and open the `web.config` for the web site or application in which the Request Filter was set. Ensure `<fileExtensions allowUnlisted="false">`. The following `web.config` will disallow any requests for files that do not have `.asp`, `.aspx`, or `.html` as their extension:

```
<configuration>
  <system.webServer>
    <security>
      <requestFiltering>
        <fileExtensions allowUnlisted="false">
          <add fileExtension=".asp" allowed="true" />
          <add fileExtension=".aspx" allowed="true" />
          <add fileExtension=".html" allowed="true" />
        </fileExtensions>
      </requestFiltering>
    </security>
  </system.webServer>
</configuration>
```

OR

To verify using `AppCmd.exe` enter the following command:

```
%systemroot%\system32\inetsrv\appcmd list config /section:requestfiltering
```

OR

To verify using PowerShell enter the following command

```
Get-WebConfigurationProperty -pspath 'MACHINE/WEBROOT/APPHOST' -filter
"system.webServer/security/requestFiltering/fileExtensions" -name
"allowUnlisted"
```


Remediation:

The `allowUnlisted` Request Filter may be set for a server, website, or application using the IIS Manager GUI, using `AppCmd.exe` commands in a command-line window, and/or directly editing the configuration files. To configure at the server level using the IIS Manager GUI:

1. Open Internet Information Services (IIS) Manager
2. In the Connections pane, select the server
3. In the Home pane, double-click Request Filtering
4. Click Edit Feature Settings... in the Actions pane
5. Under the General section, uncheck Allow unlisted file name extensions

Enter the following command in `AppCmd.exe` to configure:

```
%systemroot%\system32\inetsrv\appcmd set config /section:requestfiltering  
/fileExtensions.allowunlisted:false
```

OR

Enter the following command in PowerShell to configure:

```
Set-WebConfigurationProperty -pspath 'MACHINE/WEBROOT/APPHOST' -filter  
"system.webServer/security/requestFiltering/fileExtensions" -name  
"allowUnlisted" -value "False"
```

Default Value:

The default Request Filtering configuration allows all unlisted file extensions to be requested.

References:

1. <http://www.iis.net/ConfigReference/system.webServer/security/requestFiltering/requestLimits>
2. <http://www.iis.net/learn/manage/configuring-security/configure-request-filtering-in-iis>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v7	18 Application Software Security Application Software Security			

4.8 (L1) Ensure Handler is not granted Write and Script/Execute (Manual)

Profile Applicability:

- Level 1 - IIS 10

Description:

Handler mappings can be configured to give permissions to `Read`, `Write`, `Script`, or `Execute` depending on what the use is for - reading static content, uploading files, executing scripts, etc.

It is recommended to grant a handler either `Execute/Script` or `Write` permissions, but not both.

Rationale:

By allowing both `Execute/Script` and `Write` permissions, a handler can run malicious code on the target server. Ensuring these two permissions are never together will help lower the risk of malicious code being executed on the server.

Impact:

N/A

Audit:

Open the `ApplicationHost.config` file in `%systemroot%\system32\inetsrv\config`. Find the `<handlers>` section and verify that the `accessPolicy` attribute does not contain `Write` when `Script` or `Execute` are present. The following is an acceptable example:

```
<system.webserver>
  <handlers accessPolicy="Read, Script">
  </handlers>
</system.webserver>
```

OR

To verify using PowerShell enter the following command:

```
Get-WebConfigurationProperty -pspath 'MACHINE/WEBROOT/APPHOST' -filter
"system.webServer/handlers" -name "accessPolicy"
```

Remediation:

The `accessPolicy` attribute in the `<handlers>` section of either the `ApplicationHost.config` (server-wide) or `web.config` (site or application) must not have `Write` present when `Script` or `Execute` are present. To resolve this issue for a Web server, the attribute in the `<handlers>` section of the `ApplicationHost.config` file for the server must manually be edited. To edit the `ApplicationHost.config` file by using Notepad, perform the following steps:

1. Open Notepad as Administrator
2. Open the `ApplicationHost.config` file in `%systemroot%\system32\inetsrv\config`
3. Edit the `<handlers>` section `accessPolicy` attribute so that `Write` is not present when `Script` or `Execute` are present

Enter the following command in `AppCmd.exe` to configure:

```
%systemroot%\system32\inetsrv\appcmd set config /section:handlers
/accessPolicy:Read,Script
```

OR

Enter the following command in PowerShell to configure:

```
Set-WebConfigurationProperty -pspath 'MACHINE/WEBROOT/APPHOST' -filter
"system.webServer/handlers" -name "accessPolicy" -value "Read,Script"
```

Note: This configuration change cannot be made by using IIS Manager.

Default Value:

The default handlers `accessPolicy` is `Read, Script`.

References:

1. <http://technet.microsoft.com/en-us/library/dd391910%28WS.10%29.aspx>
2. <http://blogs.iis.net/thomad/archive/2006/11/05/quo-vadis-accessflags.aspx>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	6.8 <u>Define and Maintain Role-Based Access Control</u> Define and maintain role-based access control, through determining and documenting the access rights necessary for each role within the enterprise to successfully carry out its assigned duties. Perform access control reviews of enterprise assets to validate that all privileges are authorized, on a recurring schedule at a minimum annually, or more frequently.			●
v7	18 <u>Application Software Security</u> Application Software Security			

4.9 (L1) Ensure 'notListedIsapisAllowed' is set to false (Automated)

Profile Applicability:

- Level 1 - IIS 10

Description:

The `notListedIsapisAllowed` attribute is a server-level setting that is located in the `ApplicationHost.config` file in the `<isapiCgiRestriction>` element of the `<system.webServer>` section under `<security>`. This element ensures that malicious users cannot copy unauthorized ISAPI binaries to the Web server and then run them.

It is recommended that `notListedIsapisAllowed` be set to `false`.

Rationale:

Restricting this attribute to `false` will help prevent potentially malicious ISAPI extensions from being run.

Impact:

Unauthorized ISAPI binaries will not be allowed.

Audit:

Open the `applicationHost.config` file in `%systemroot%\system32\inetsrv\config`. Verify that the `notListedIsapisAllowed` attribute in the `<isapiCgiRestriction>` element is set to `false`:

```
<system.webServer>
  <security>
    <isapiCgiRestriction notListedIsapisAllowed="false">
    </isapiCgiRestriction>
  </security>
</system.webServer>
```

OR

To verify using PowerShell enter the following command:

```
Get-WebConfigurationProperty -pspath 'MACHINE/WEBROOT/APPHOST' -filter
"system.webServer/security/isapiCgiRestriction" -name
"notListedIsapisAllowed"
```

Remediation:

To use IIS Manager to set the `notListedIsapisAllowed` attribute to `false`:

1. Open IIS Manager as Administrator
2. In the Connections pane on the left, select server to be configured
3. In Features View, select ISAPI and CGI Restrictions; in the Actions pane, select Open Feature
4. In the Actions pane, select Edit Feature Settings
5. In the Edit ISAPI and CGI Restrictions Settings dialog, clear the Allow unspecified ISAPI modules check box, if checked
6. Click OK

Enter the following command in AppCmd.exe to configure:

```
%systemroot%\system32\inetsrv\appcmd.exe set config -  
section:system.webServer/security/isapiCgiRestriction  
/notListedIsapisAllowed:false
```

OR

Enter the following command in PowerShell to configure:

```
Set-WebConfigurationProperty -pspath 'MACHINE/WEBROOT/APPHOST' -filter  
"system.webServer/security/isapiCgiRestriction" -name  
"notListedIsapisAllowed" -value "False"
```

Default Value:

The default value for `notListedIsapisAllowed` is `false`.

References:

1. <http://technet.microsoft.com/en-us/library/dd378846%28WS.10%29.aspx>
2. <http://www.iis.net/ConfigReference/system.webServer/security/isapiCgiRestriction>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v7	18 <u>Application Software Security</u> Application Software Security			

4.10 (L1) Ensure 'notListedCgisAllowed' is set to false (Automated)

Profile Applicability:

- Level 1 - IIS 10

Description:

The `notListedCgisAllowed` attribute is a server-level setting that is located in the `ApplicationHost.config` file in the `<isapiCgiRestriction>` element of the `<system.webServer>` section under `<security>`. This element ensures that malicious users cannot copy unauthorized CGI binaries to the Web server and then run them.

It is recommended that `notListedCgisAllowed` be set to `false`.

Rationale:

Restricting this attribute to `false` will help prevent unlisted CGI extensions, including potentially malicious CGI scripts from being run.

Impact:

Unlisted CGI extensions will not be allowed.

Audit:

Browse to and open the `applicationHost.config` file and verify that the `notListedCgisAllowed` attribute in the `<isapiCgiRestriction>` element is set to `false`:

```
<system.webServer>
  <security>
    <isapiCgiRestriction notListedCgisAllowed="false">
    </isapiCgiRestriction>
  </security>
</system.webServer>
```

OR

To verify using PowerShell enter the following command:

```
Get-WebConfigurationProperty -pspath 'MACHINE/WEBROOT/APPHOST' -filter
"system.webServer/security/isapiCgiRestriction" -name "notListedCgisAllowed"
```

Remediation:

To set the `notListedCgisAllowed` attribute to false using IIS Manager:

1. Open IIS Manager as Administrator
2. In the Connections pane on the left, select the server to configure
3. In Features View, select ISAPI and CGI Restrictions; in the Actions pane, select Open Feature
4. In the Actions pane, select Edit Feature Settings
5. In the Edit ISAPI and CGI Restrictions Settings dialog, clear the Allow unspecified CGI modules check box
6. Click OK

Enter the following command in `AppCmd.exe` to configure:

```
%systemroot%\system32\inetsrv\appcmd.exe set config -  
section:system.webServer/security/isapiCgiRestriction  
/notListedCgisAllowed:false
```

OR

Enter the following command in PowerShell to configure:

```
Set-WebConfigurationProperty -pspath 'MACHINE/WEBROOT/APPHOST' -filter  
"system.webServer/security/isapiCgiRestriction" -name "notListedCgisAllowed"  
-value "False"
```

Default Value:

The default value for `notListedCgisAllowed` is false.

References:

1. <http://technet.microsoft.com/en-us/library/dd391919%28WS.10%29.aspx>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v7	18 <u>Application Software Security</u> Application Software Security			

4.11 (L1) Ensure 'Dynamic IP Address Restrictions' is enabled (Manual)

Profile Applicability:

- Level 1 - IIS 10

Description:

Dynamic IP address filtering allows administrators to configure the server to block access for IPs that exceed the specified number of requests or request frequency.

Note: Ensure that you receive the Forbidden page once the block has been enforced.

Rationale:

IIS Dynamic IP Address Restrictions capability can be used to thwart DDos attacks. This is complimentary to the IP Addresses and Domain names Restrictions lists that can be manually maintained within IIS. In contrast, Dynamic IP address filtering allows administrators to configure the server to block access for IPs that exceed the specified request threshold. The default action Deny action for restrictions is to return a Forbidden response to the client.

Impact:

Clients will receive a forbidden response when the specified number of requests or request frequency is exceeded.

Audit:

Access the web server enough times to trigger the IP restriction based on the settings entered.

OR

To verify using PowerShell enter the following command:

```
Get-WebConfigurationProperty -pspath 'MACHINE/WEBROOT/APPHOST' -filter "system.webServer/security/dynamicIpSecurity/denyByConcurrentRequests" -name "enabled"
Get-WebConfigurationProperty -pspath 'MACHINE/WEBROOT/APPHOST' -filter "system.webServer/security/dynamicIpSecurity/denyByConcurrentRequests" -name "maxConcurrentRequests"
```

Remediation:

1. Open IIS Manager.
2. Open the IP Address and Domain Restrictions feature.
3. Click Edit Dynamic Restrictions Settings..
4. Check the Deny IP Address based on the number of concurrent requests and the Deny IP Address based on the number of requests over a period of time boxes. The values can be tweaked as needed for your specific environment.

OR

Enter the following command in PowerShell to configure:

```
Set-WebConfigurationProperty -pspath 'MACHINE/WEBROOT/APPHOST' -filter "system.webServer/security/dynamicIpSecurity/denyByConcurrentRequests" -name "enabled" -value "True"
Set-WebConfigurationProperty -pspath 'MACHINE/WEBROOT/APPHOST' -filter "system.webServer/security/dynamicIpSecurity/denyByConcurrentRequests" -name "maxConcurrentRequests" -value <number of requests>
```

Default Value:

By default Dynamic IP Restrictions are not enabled.

References:

1. <http://www.iis.net/learn/get-started/whats-new-in-iis-8/iis-80-dynamic-ip-address-restrictions>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	13.10 Perform Application Layer Filtering Perform application layer filtering. Example implementations include a filtering proxy, application layer firewall, or gateway.			●
v7	9.5 Implement Application Firewalls Place application firewalls in front of any critical servers to verify and validate the traffic going to the server. Any unauthorized traffic should be blocked and logged.			●

5 IIS Logging Recommendations

This section contains recommendations regarding IIS logging that have not been covered in the Basic Configurations section.

5.1 (L1) Ensure Default IIS web log location is moved (Automated)

Profile Applicability:

- Level 1 - IIS 10

Description:

IIS will log relatively detailed information on every request. These logs are usually the first item looked at in a security response and can be the most valuable. Malicious users are aware of this and will often try to remove evidence of their activities.

It is recommended that the default location for IIS log files be changed to a restricted, non-system drive.

Rationale:

Moving IIS logging to a restricted, non-system drive will help mitigate the risk of logs being maliciously altered, removed, or lost in the event of system drive failure(s).

Impact:

If an administrator needs access to the log file, that does not have drive permission, they will be unable to view that file.

Audit:

To verify web logs are being logged to the new location, open Windows Explorer and browse to the path that was defined. Depending on how the logging was configured, there will be either:

1. A folder containing .log files or
2. .log files in the root of the specified directory

OR

To verify using PowerShell enter the following command:

```
Get-WebConfigurationProperty -pspath 'MACHINE/WEBROOT/APPHOST' -filter  
"system.applicationHost/sites/siteDefaults/logFile" -name "directory"
```

Remediation:

Moving the default log location can be easily accomplished using the Logging feature in the IIS Management UI, AppCmd.exe, or PowerShell.

Enter the following command in AppCmd.exe to configure:

```
%systemroot%\system32\inetsrv\appcmd set config -section:sites -  
siteDefaults.logfile.directory:<new log location>
```

OR

Enter the following command in PowerShell to configure:

```
Set-WebConfigurationProperty -pspath 'MACHINE/WEBROOT/APPHOST' -filter  
"system.applicationHost/sites/siteDefaults/logFile" -name "directory" -value  
<new log location>
```

Moving log file stores to a non-system drive or partition separate from where web applications run and/or content is served is preferred. Additionally, folder-level NTFS permissions should be set as restrictive as possible; Administrators and SYSTEM are typically the only principals requiring access.

While standard IIS logs can be moved and edited using IIS Manager, additional management tool add-ons are required in order to manage logs generated by other IIS features, such as Request Filtering and IIS Advanced Logging. These add-ons can be obtained using the Web Platform Installer or from Microsoft's site. The HTTPErr logging location can be changed by adding a registry key.

Default Value:

The default location for web logs in IIS is: %SystemDrive%\inetpub\logs\LogFiles.

References:

1. [https://technet.microsoft.com/en-us/library/cc770709\(v=ws.10\).aspx?](https://technet.microsoft.com/en-us/library/cc770709(v=ws.10).aspx?)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.3 <u>Ensure Adequate Audit Log Storage</u> Ensure that logging destinations maintain adequate storage to comply with the enterprise's audit log management process.			
v7	6.4 <u>Ensure adequate storage for logs</u> Ensure that all systems that store logs have adequate storage space for the logs generated.			

5.2 (L1) Ensure Advanced IIS logging is enabled (Automated)

Profile Applicability:

- Level 1 - IIS 10

Description:

IIS Advanced Logging is a module which provides flexibility in logging requests and client data. It provides controls that allow businesses to specify what fields are important, easily add additional fields, and provide policies pertaining to log file rollover and Request Filtering. HTTP request/response headers, server variables, and client-side fields can be easily logged with minor configuration in the IIS management console.

Rationale:

Many of the fields available in Advanced Logging can provide extensive, real-time data and details not otherwise obtainable. Developers and security professionals can use this information to identify and remediate application vulnerabilities/attack patterns.

Impact:

Collecting detailed log files will take more space on the specified drive.

Audit:

Browse to the location of the Advanced Logs and verify .log files are being generated. Note that logs will be written to disk after a non-determined period of time. They can be written into their specified directory immediately if, in the Log Definition, the Publish real-time events and Write to disk options are selected.

Remediation:

IIS Advanced Logging can be configured for servers, Web sites, and directories in IIS Manager. To enable Advanced Logging using the UI:

1. Open Internet Information Services (IIS) Manager
2. Click the server in the Connections pane
3. Double-click the Logging icon on the Home page
4. Click Select Fields

The fields that will be logged need to be configured using the Add or Edit Fields button. Note: There may be performance considerations depending on the extent of the configuration.

Default Value:

IIS Advanced Logging is enabled by default.

References:

1. <https://www.iis.net/learn/get-started/whats-new-in-iis-85/enhanced-logging-for-iis85>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.5 <u>Collect Detailed Audit Logs</u> Configure detailed audit logging for enterprise assets containing sensitive data. Include event source, date, username, timestamp, source addresses, destination addresses, and other useful elements that could assist in a forensic investigation.		●	●
v7	6.2 <u>Activate audit logging</u> Ensure that local logging has been enabled on all systems and networking devices.	●	●	●
v7	6.3 <u>Enable Detailed Logging</u> Enable system logging to include detailed information such as an event source, date, user, timestamp, source addresses, destination addresses, and other useful elements.		●	●

5.3 (L1) Ensure 'ETW Logging' is enabled (Manual)

Profile Applicability:

- Level 1 - IIS 10

Description:

Event Tracing for Windows (ETW) is a Windows feature that allows Administrators to send logging information to another location. This information is then compiled on the server and can be queried.

Rationale:

IIS flushes log information to disk, therefore prior to IIS, administrators do not have access to real-time logging information. Text-based log files can also be difficult and time consuming to process. By enabling ETW, administrators have access to use standard query tools for viewing real-time logging information.

Impact:

A dedicated server hosting Event Tracing for Windows (ETW) will be needed.

Audit:

Using Message Analyzer, configure the query for Microsoft-Windows-IIS-Logging. Verify you see live logging data by accessing the website.

Remediation:

To configure ETW logging:

1. Open IIS Manager
2. Select the server or site to enable ETW
3. Select Logging.
4. Ensure Log file format is W3C.
5. Select Both log file and ETW event
6. Save your settings.

References:

1. <http://www.iis.net/learn/get-started/whats-new-in-iis-85/logging-to-etw-in-iis-85>
2. http://blogs.technet.com/b/erezs_iis_blog/archive/2013/07/15/hook-me-up.aspx
3. <https://blogs.msdn.microsoft.com/dcook/2015/09/30/etw-overview/>
4. <https://social.msdn.microsoft.com/Forums/en-US/a1aa1350-41a0-4490-9ae3-9b4520aeb9d4/faq-common-questions-for-etw-and-windows-event-log?forum=etw>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.9 <u>Centralize Audit Logs</u> Centralize, to the extent possible, audit log collection and retention across enterprise assets.		●	●
v7	6.6 <u>Deploy SIEM or Log Analytic tool</u> Deploy Security Information and Event Management (SIEM) or log analytic tool for log correlation and analysis.		●	●
v7	6.8 <u>Regularly Tune SIEM</u> On a regular basis, tune your SIEM system to better identify actionable events and decrease event noise.			●

6 FTP Requests

This section contains a crucial configuration setting for running file transfer protocol (FTP).

6.1 (L1) Ensure FTP requests are encrypted (Manual)

Profile Applicability:

- Level 1 - IIS 10

Description:

FTP Publishing Service for IIS supports adding an SSL certificate to an FTP site. Using an SSL certificate with an FTP site is also known as FTP-S or FTP over Secure Socket Layers (SSL). FTP-S is an RFC standard (RFC 4217) where an SSL certificate is added to an FTP site and thereby making it possible to perform secure file transfers.

Rationale:

By using SSL, the FTP transmission is encrypted and secured from point to point and all FTP traffic as well as credentials are thereby guarded against interception.

Impact:

SSL will be needed for the FTP transmission.

Audit:

To verify using PowerShell enter the following commands:

```
Get-WebConfigurationProperty -pspath 'MACHINE/WEBROOT/APPHOST' -filter  
"system.applicationHost/sites/siteDefaults/ftpServer/security/ssl" -name  
"controlChannelPolicy"  
Get-WebConfigurationProperty -pspath 'MACHINE/WEBROOT/APPHOST' -filter  
"system.applicationHost/sites/siteDefaults/ftpServer/security/ssl" -name  
"dataChannelPolicy"
```

The output should be SslRequire for both commands.

Remediation:

To configure FTP over SSL at the server level using AppCmd.exe or PowerShell:
Enter the following command in AppCmd.exe to configure:

```
%systemroot%\system32\inetsrv\appcmd.exe set config -  
section:system.applicationHost/sites  
/siteDefaults.ftpServer.security.ssl.controlChannelPolicy:"SslRequire"  
/siteDefaults.ftpServer.security.ssl.dataChannelPolicy:"SslRequire"  
/commit:apphost
```

OR

Enter the following commands in PowerShell to configure:

```
Set-WebConfigurationProperty -pspath 'MACHINE/WEBROOT/APPHOST' -filter  
"system.applicationHost/sites/siteDefaults/ftpServer/security/ssl" -name  
"controlChannelPolicy" -value "SslRequire"  
Set-WebConfigurationProperty -pspath 'MACHINE/WEBROOT/APPHOST' -filter  
"system.applicationHost/sites/siteDefaults/ftpServer/security/ssl" -name  
"dataChannelPolicy" -value "SslRequire"
```

Default Value:

By default, FTP sites are not SSL enabled.

References:

1. http://www.windowsnetworking.com/articles_tutorials/IIS-FTP-Publishing-Service-Part3.html
2. <http://learn.iis.net/page.aspx/304/using-ftp-over-ssl/#03>
3. <https://tools.ietf.org/html/rfc4217>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.10 <u>Encrypt Sensitive Data in Transit</u> Encrypt sensitive data in transit. Example implementations can include: Transport Layer Security (TLS) and Open Secure Shell (OpenSSH).			
v7	14.4 <u>Encrypt All Sensitive Information in Transit</u> Encrypt all sensitive information in transit.			

6.2 (L1) Ensure FTP Logon attempt restrictions is enabled (Manual)

Profile Applicability:

- Level 1 - IIS 10

Description:

FTP Logon attempt restrictions is a built-in network security feature to automatically block brute force FTP attacks. This can be used to mitigate a malicious client from attempting a brute-force attack on a discovered account, such as the local administrator account.

Rationale:

Successful brute force FTP attacks can allow an otherwise unauthorized user to make changes to data that should not be made. This could allow the unauthorized user to modify website code by uploading malicious software or even changing functionality for items such as online payments.

Impact:

N/A

Audit:

To verify using AppCmd.exe enter the following command:

```
%systemroot%\system32\inetsrv\appcmd.exe list config -  
section:system.ftpServer/security/authentication
```

The output should include denyByFailure = true

OR

To verify using PowerShell enter the following command:

```
Get-WebConfigurationProperty -pspath 'MACHINE/WEBROOT/APPHOST' -filter  
"system.ftpServer/security/authentication/denyByFailure" -name "enabled"
```

Remediation:

To configure FTP Logon Attempt Restrictions at the server level using AppCmd.exe or PowerShell:

Enter the following command in AppCmd.exe to configure:

```
%systemroot%\system32\inetsrv\appcmd.exe set config -  
section:system.ftpServer/security/authentication  
/denyByFailure.enabled:"True" /commit:apphost
```

OR

Enter the following command in PowerShell to configure:

```
Set-WebConfigurationProperty -pspath 'MACHINE/WEBROOT/APPHOST' -filter  
"system.ftpServer/security/authentication/denyByFailure" -name "enabled" -  
value "True"
```

Default Value:

By default, this feature is not enabled when FTP is installed.

References:

1. <http://www.iis.net/learn/get-started/whats-new-in-iis-8/iis-80-ftp-logon-attempt-restrictions>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	10.5 Enable Anti-Exploitation Features Enable anti-exploitation features on enterprise assets and software, where possible, such as Microsoft® Data Execution Prevention (DEP), Windows® Defender Exploit Guard (WDEG), or Apple® System Integrity Protection (SIP) and Gatekeeper™.			
v7	9.1 Associate Active Ports, Services and Protocols to Asset Inventory Associate active ports, services and protocols to the hardware assets in the asset inventory.			

7 Transport Encryption

This section contains recommendations for configuring IIS protocols and cipher suites.

For security protocols (SSL, TLS), there are 2 registry paths that control a protocol state in the O/S: TLS client and TLS server. A web server normally acts as the TLS server in that it is serving web content to clients. There are some instances where a web server is configured as a 'client'. An example of a server acting as a client can be seen when there is dynamic content generation. The webserver queries a remote database server to return content specific to a user's request. In this configuration, the web server is acting as a TLS client. In cases such as these, the configured TLS server protocol and cipher suite preferences take precedence over the client's. This behavior is why for the IIS benchmark we require specific protocol settings for a TLS server and only recommend settings for TLS clients.

If SSLv3 registry keys are not set, the O/S defaults take precedence.

For example, to disable SSLv3 protocol on the TLS server, you need to set the following registry key to 0:

```
HKLM\System\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\SSL 3.0\Server\Enabled
```

To prevent a client from issuing the Hello command over that legacy protocol the following registry must be set to 0:

```
HKLM\System\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\SSL 3.0\Client\Enabled
```

The fact that the key is named Enabled can be confusing. The setting of the value to either 0 or 1 actually sets the state of the protocol. 0 being disabled and 1 being enabled.

Here are some specifics into how "Enabled" and "DisabledByDefault" registry settings work. The following article, [How to restrict the use of certain cryptographic algorithms and protocols in Schannel.dll](#), provides additional information related to controlling these protocols and ciphers.

Using the "Enabled = 0" registry setting disables the protocol in a way that can't be overridden by application settings. This is the only robust way to prevent the protocol from being used and no additional settings are required. At the same time, using the "DisabledByDefault" registry setting only prevents that protocol from issuing the Hello command over that protocol when an SSL connection with a server is initiated. This O/S level setting can be overridden by an application which has application specific TLS coding. An example of this can be shown by setting the protocol within a line of code in your .Net 4.5 application: `ServicePointManager.SecurityProtocol = SecurityProtocolType.Tls12`. This can override the O/S setting if the DisabledByDefault key is present. "DisabledByDefault" is useful in the case when you want to have some control over the system settings but also allow an application to explicitly specify the protocols they would like to use.

Enabled only works strongly in the negative case ("Enabled = 0"). If "Enabled=1" or is not set, then "DisabledByDefault" will override in the case where the application takes the system defaults. "Enabled=1" is also overridden by application specific protocol flags.

7.1 (L2) Ensure HSTS Header is set (Manual)

Profile Applicability:

- Level 2 - IIS 10

Description:

HTTP Strict Transport Security (HSTS) allows a site to inform the user agent to communicate with the site only over HTTPS. This header takes two parameters: max-age, "specifies the number of seconds, after the reception of the STS header field, during which the user agent regards the host (from whom the message was received) as a Known HSTS Host [speaks only HTTPS]"; and includeSubDomains. includeSubDomains is an optional directive that defines how this policy is applied to subdomains. If includeSubDomains is included in the header, it provides the following definition: this HSTS Policy also applies to any hosts whose domain names are subdomains of the Known HSTS Host's domain name.

Rationale:

HTTP Strict Transport Security (HSTS) is a simple and widely supported standard to protect visitors by ensuring that their browsers always connect to a website over HTTPS. HSTS exists to remove the need for the common, insecure practice of redirecting users from http:// to https:// URLs. HSTS relies on the User Agent/Browser to enforce the required behavior. All major browsers support it. If the browser doesn't support HSTS, it will be ignored.

When a browser knows that a domain has enabled HSTS, it does two things:

1. Always uses an https:// connection, even when clicking on an http:// link or after typing a domain into the location bar without specifying a protocol.
2. Removes the ability for users to click through warnings about invalid certificates.

A domain instructs browsers that it has enabled HSTS by returning an HTTP header over an HTTPS connection.

Impact:

The user agent will only be able to communicate with the site over HTTPS.

Audit:

The recommended max age is 8 minutes (480 seconds) or greater. Any value greater than 0 is acceptable. Perform the following in IIS Manager to view host headers configured for the server:

1. Open IIS Manager
2. In the Connections pane, select your server
3. In the Features View pane, double click HTTP Response Headers
4. Verify an entry exists named Strict-Transport-Security
5. Double click Strict-Transport-Security and verify the Value: box contains any value greater than 0
6. Click OK.

Perform the following in IIS Manager to view host headers configured for the Website:

1. Open IIS Manager
2. In the Connections pane, expand the tree and select Website
3. In the Features View pane, double click HTTP Response Headers
4. Verify an entry exists name Strict-Transport-Security
5. Double click Strict-Transport-Security and verify the Value: box contains any value greater than 0
6. Click OK.

Remediation:

Any value greater than 0 meets this recommendation. The examples below are specific to 8 minutes but can be adjusted to meet your requirements.

To set the HTTP Header at the server level using an `AppCmd.exe` command, run the following command from an elevated command prompt:

```
%systemroot%\system32\inetsrv\appcmd.exe set config -  
section:system.webServer/httpProtocol /+"customHeaders.[name='Strict-  
Transport-Security',value='max-age=480; preload']"
```

To set the HTTP Header and include subdomains at the server level using an `AppCmd.exe` command, run the following command from an elevated command prompt:

```
%systemroot%\system32\inetsrv\appcmd.exe set config -  
section:system.webServer/httpProtocol /+"customHeaders.[name='Strict-  
Transport-Security',value='max-age=480; includeSubDomains; preload']"
```

To set the HTTP Header at the Website level using an `AppCmd.exe` command, run the following command from an elevated command prompt:

```
%systemroot%\system32\inetsrv\appcmd.exe set config "<em>Website"</em> -  
section:system.webServer/httpProtocol /+"customHeaders.[name='Strict-  
Transport-Security',value='max-age=480; preload']"
```

To set the HTTP Header and include subdomains at the Website level using an `AppCmd.exe` command, run the following command from an elevated command prompt:

```
%systemroot%\system32\inetsrv\appcmd.exe set config "<em>Website"</em> -  
section:system.webServer/httpProtocol /+"customHeaders.[name='Strict-  
Transport-Security',value='max-age=480; includeSubDomains; preload']"
```

References:

1. <http://tools.ietf.org/html/rfc6797#section-5.1>
2. <https://https.cio.gov/hsts/>
3. <https://www.iis.net/configreference/system.webserver/httpprotocol/customheaders#006>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.10 <u>Encrypt Sensitive Data in Transit</u> Encrypt sensitive data in transit. Example implementations can include: Transport Layer Security (TLS) and Open Secure Shell (OpenSSH).			
v7	18 <u>Application Software Security</u> Application Software Security			

7.2 (L1) Ensure SSLv2 is Disabled (Automated)

Profile Applicability:

- Level 1 - IIS 10

Description:

The SSLv2 protocol is not considered cryptographically secure, therefore should be disabled.

Rationale:

Disabling weak protocols will help ensure the confidentiality and integrity of in-transit data.

Impact:

The SSLv2 protocol will not be available for use.

Audit:

Perform the following to verify SSL 2.0 is disabled.

1. Ensure the following key is set to 0.

```
HKLM\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\SSL 2.0\Server:Enabled
HKLM\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\SSL 2.0\Client:Enabled
```

2. Ensure the following key is set to 1.

```
HKLM\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\SSL 2.0\Server:DisabledByDefault
HKLM\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\SSL 2.0\Client:DisabledByDefault
```

To verify using PowerShell enter the following command:

```
Get-ItemProperty -path
'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\SSL 2.0\Server' -name 'Enabled'
Get-ItemProperty -path
'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\SSL 2.0\Client' -name 'Enabled'
Get-ItemProperty -path
'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\SSL 2.0\Server' -name 'DisabledByDefault'
Get-ItemProperty -path
'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\SSL 2.0\Client' -name 'DisabledByDefault'
```

Remediation:

Perform the following to disable SSL 2.0:

1. Set the following Registry key to 0.

```
HKLM\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\SSL 2.0\Server:Enabled
HKLM\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\SSL 2.0\Client:Enabled
```

2. Set the following Registry key to 1.

```
HKLM\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\SSL 2.0\Server:DisabledByDefault
HKLM\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\SSL 2.0\Client:DisabledByDefault
```

To disable using PowerShell enter the following command:

```
New-Item
'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\SSL 2.0\Server' -Force | Out-Null

New-Item
'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\SSL 2.0\Client' -Force | Out-Null

New-ItemProperty -path
'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\SSL 2.0\Server' -name 'Enabled' -value '0' -PropertyType 'DWord' -Force | Out-Null

New-ItemProperty -path
'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\SSL 2.0\Client' -name 'Enabled' -value '0' -PropertyType 'DWord' -Force | Out-Null

New-ItemProperty -path
'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\SSL 2.0\Server' -name 'DisabledByDefault' -value '1' -PropertyType 'DWord' -Force | Out-Null

New-ItemProperty -path
'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\SSL 2.0\Client' -name 'DisabledByDefault' -value '1' -PropertyType 'DWord' -Force | Out-Null
```

Default Value:

Enabled

References:

1. <http://technet.microsoft.com/en-us/library/dn786419.aspx>
2. <http://technet.microsoft.com/en-us/library/dn786433.aspx>
3. <http://msdn.microsoft.com/en-us/library/aa374757%28v=vs.85%29.aspx>
4. https://www.owasp.org/index.php/Testing_for_SSL-TLS_%28OWASP-CM-001%29

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	13.10 Perform Application Layer Filtering Perform application layer filtering. Example implementations include a filtering proxy, application layer firewall, or gateway.			
v7	14.4 Encrypt All Sensitive Information in Transit Encrypt all sensitive information in transit.			

7.3 (L1) Ensure SSLv3 is Disabled (Automated)

Profile Applicability:

- Level 1 - IIS 10

Description:

The SSLv3 protocol is not considered cryptographically secure, therefore should be disabled.

Rationale:

Disabling weak protocols will help ensure the confidentiality and integrity of in-transit data.

Impact:

The SSLv3 protocol will not be available.

Audit:

Perform the following to verify SSL 3.0 is disabled:

1. Ensure the following key is set to 0.

```
HKLM\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\SSL 3.0\Server:Enabled
HKLM\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\SSL 3.0\Client:Enabled
```

2. Ensure the following key is set to 1.

```
HKLM\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\SSL 3.0\Server:DisabledByDefault
HKLM\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\SSL 3.0\Client:DisabledByDefault
```

To verify using PowerShell enter the following command:

```
Get-ItemProperty -path
'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\SSL 3.0\Server' -name 'Enabled'

Get-ItemProperty -path
'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\SSL 3.0\Client' -name 'Enabled'

Get-ItemProperty -path
'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\SSL 3.0\Server' -name 'DisabledByDefault'

Get-ItemProperty -path
'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\SSL 3.0\Client' -name 'DisabledByDefault'
```

Remediation:

Perform the following to disable SSL 3.0:

1. Set the following Registry key to 0.

```
HKLM\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\SSL 3.0\Server:Enabled
HKLM\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\SSL 3.0\Client:Enabled
```

2. Set the following Registry key to 1.

```
HKLM\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\SSL 3.0\Server:DisabledByDefault
HKLM\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\SSL 3.0\Client:DisabledByDefault
```

To disable using PowerShell enter the following command:

```
New-Item
'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\SSL 3.0\Server' -Force | Out-Null

New-Item
'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\SSL 3.0\Client' -Force | Out-Null

New-ItemProperty -path
'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\SSL 3.0\Server' -name 'Enabled' -value '0' -PropertyType 'DWord' -Force | Out-Null

New-ItemProperty -path
'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\SSL 3.0\Client' -name 'Enabled' -value '0' -PropertyType 'DWord' -Force | Out-Null

New-ItemProperty -path
'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\SSL 3.0\Server' -name 'DisabledByDefault' -value '1' -PropertyType 'DWord' -Force | Out-Null

New-ItemProperty -path
'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\SSL 3.0\Client' -name 'DisabledByDefault' -value '1' -PropertyType 'DWord' -Force | Out-Null
```

Default Value:

Enabled

References:

1. <https://www.openssl.org/~bodo/ssl-poodle.pdf>
2. <http://technet.microsoft.com/en-us/library/dn786419.aspx>
3. https://www.owasp.org/index.php/Testing_for_SSL-TLS_%28OWASP-CM-001%29
4. <http://technet.microsoft.com/en-us/library/dn786433.aspx>
5. <http://msdn.microsoft.com/en-us/library/aa374757%28v=vs.85%29.aspx>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.10 <u>Encrypt Sensitive Data in Transit</u> Encrypt sensitive data in transit. Example implementations can include: Transport Layer Security (TLS) and Open Secure Shell (OpenSSH).			
v7	14.4 <u>Encrypt All Sensitive Information in Transit</u> Encrypt all sensitive information in transit.			

7.4 (L1) Ensure TLS 1.0 is Disabled (Automated)

Profile Applicability:

- Level 1 - IIS 10

Description:

The TLS 1.0 protocol is not considered cryptographically secure, therefore should be disabled.

Rationale:

Disabling weak protocols will help ensure the confidentiality and integrity of in-transit data.

Impact:

The TLS 1.0 protocol will not be available.

Audit:

Perform the following to verify TLS 1.0 is disabled:

1. Ensure the following Registry key is set to 0.

```
HKLM\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\TLS 1.0\Server:Enabled
HKLM\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\TLS 1.0\Client:Enabled
```

2. Ensure the following Registry key is set to 1.

```
HKLM\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\TLS 1.0\Server:DisabledByDefault
HKLM\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\TLS 1.0\Client:DisabledByDefault
```

To verify using PowerShell enter the following command:

```
Get-ItemProperty -path
'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\TLS 1.0\Server' -name 'Enabled'

Get-ItemProperty -path
'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\TLS 1.0\Client' -name 'Enabled'

Get-ItemProperty -path
'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\TLS 1.0\Server' -name 'DisabledByDefault'

Get-ItemProperty -path
'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\TLS 1.0\Client' -name 'DisabledByDefault'
```

Remediation:

Perform the following to disable TLS 1.0:

1. Set the following Registry key to 0.

```
HKLM\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\TLS 1.0\Server:Enabled
HKLM\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\TLS 1.0\Client:Enabled
```

2. Set the following Registry key to 1.

```
HKLM\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\TLS 1.0\Server:DisabledByDefault
HKLM\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\TLS 1.0\Client:DisabledByDefault
```

To disable using PowerShell enter the following command:

```
New-Item
'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\
TLS 1.0\Server' -Force | Out-Null

New-Item
'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\
TLS 1.0\Client' -Force | Out-Null

New-ItemProperty -path
'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\
TLS 1.0\Server' -name 'Enabled' -value '0' -PropertyType 'DWord' -Force |
Out-Null

New-ItemProperty -path
'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\
TLS 1.0\Client' -name 'Enabled' -value '0' -PropertyType 'DWord' -Force |
Out-Null

New-ItemProperty -path
'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\
TLS 1.0\Server' -name 'DisabledByDefault' -value '1' -PropertyType 'DWord' -
Force | Out-Null

New-ItemProperty -path
'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\
TLS 1.0\Client' -name 'DisabledByDefault' -value '1' -PropertyType 'DWord' -
Force | Out-Null
```

References:

1. <http://msdn.microsoft.com/en-us/library/aa374757%28v=vs.85%29.aspx>
2. https://www.owasp.org/index.php/Testing_for_SSL-TLS_%28OWASP-CM-001%29
3. <http://technet.microsoft.com/en-us/library/dn786419.aspx>
4. <http://technet.microsoft.com/en-us/library/dn786433.aspx>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.10 <u>Encrypt Sensitive Data in Transit</u> Encrypt sensitive data in transit. Example implementations can include: Transport Layer Security (TLS) and Open Secure Shell (OpenSSH).			
v7	14.4 <u>Encrypt All Sensitive Information in Transit</u> Encrypt all sensitive information in transit.			

7.5 (L1) Ensure TLS 1.1 is Disabled (Automated)

Profile Applicability:

- Level 1 - IIS 10

Description:

The TLS 1.1 protocol is not considered cryptographically secure, therefore should be disabled.

Rationale:

Disabling weak protocols will help ensure the confidentiality and integrity of in-transit data.

Impact:

TLS 1.1 may be needed for backward compatibility.

Warning: Fully test the application to ensure that backwards compatibility is not needed. If it is, build in exceptions as necessary for backwards compatibility.

Audit:

Perform the following to verify TLS 1.1 is disabled:

1. Ensure the following Registry key is set to 0.

```
HKLM\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\TLS 1.1\Server:Enabled
HKLM\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\TLS 1.1\Client:Enabled
```

2. Ensure the following Registry key is set to 1.

```
HKLM\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\TLS 1.1\Server:DisabledByDefault
HKLM\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\TLS 1.1\Client:DisabledByDefault
```

To verify using PowerShell enter the following command:

```
Get-ItemProperty -path
'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\TLS 1.1\Server' -name 'Enabled'

Get-ItemProperty -path
'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\TLS 1.1\Client' -name 'Enabled'

Get-ItemProperty -path
'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\TLS 1.1\Server' -name 'DisabledByDefault'

Get-ItemProperty -path
'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\TLS 1.1\Client' -name 'DisabledByDefault'
```

Remediation:

Perform the following to disable TLS 1.1:

1. Set the following Registry key to 0.

```
HKLM\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\TLS 1.1\Server:Enabled
HKLM\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\TLS 1.1\Client:Enabled
```

2. Set the following Registry key to 1.

```
HKLM\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\TLS 1.1\Server:DisabledByDefault
HKLM\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\TLS 1.1\Client:DisabledByDefault
```

To disable using PowerShell enter the following command:

```
New-Item
'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\
TLS 1.1\Server' -Force | Out-Null

New-Item
'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\
TLS 1.1\Client' -Force | Out-Null

New-ItemProperty -path
'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\
TLS 1.1\Server' -name 'Enabled' -value '0' -PropertyType 'DWord' -Force |
Out-Null

New-ItemProperty -path
'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\
TLS 1.1\Client' -name 'Enabled' -value '0' -PropertyType 'DWord' -Force |
Out-Null

New-ItemProperty -path
'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\
TLS 1.1\Server' -name 'DisabledByDefault' -value '1' -PropertyType 'DWord' -
Force | Out-Null

New-ItemProperty -path
'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\
TLS 1.1\Client' -name 'DisabledByDefault' -value '1' -PropertyType 'DWord' -
Force | Out-Null
```

References:

1. <http://technet.microsoft.com/en-us/library/dn786433.aspx>
2. https://www.owasp.org/index.php/Testing_for_SSL-TLS_%28OWASP-CM-001%29
3. <http://technet.microsoft.com/en-us/library/dn786419.aspx>
4. <http://msdn.microsoft.com/en-us/library/aa374757%28v=vs.85%29.aspx>
5. <https://community.qualys.com/thread/16565-is-there-a-reason-for-still-having-tlsv11-enabled>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	13.10 Perform Application Layer Filtering Perform application layer filtering. Example implementations include a filtering proxy, application layer firewall, or gateway.			
v7	14.4 Encrypt All Sensitive Information in Transit Encrypt all sensitive information in transit.			

7.6 (L1) Ensure TLS 1.2 is Enabled (Automated)

Profile Applicability:

- Level 1 - IIS 10

Description:

TLS 1.2 is the most recent and mature protocol for protecting the confidentiality and integrity of HTTP traffic.

Rationale:

Enabling this protocol will help ensure the confidentiality and integrity of data in transit.

Impact:

N/A

Audit:

Perform the following to verify TLS 1.2 is enabled:

1. Ensure the following Registry key is set to 1.

```
HKLM\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\TLS 1.2\Server:Enabled
```

2. Ensure the following Registry key is set to 0.

```
HKLM\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\TLS 1.2\Server:DisabledByDefault
```

To verify using PowerShell enter the following command:

```
Get-ItemProperty -path  
'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocol  
s\TLS 1.2\Server' -name 'Enabled'  
  
Get-ItemProperty -path  
'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocol  
s\TLS 1.2\Server' -name 'DisabledByDefault'
```

Remediation:

Perform the following to enable TLS 1.2:

1. Set the following Registry key to 1.

```
HKLM\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\TLS 1.2\Server:Enabled
```

2. Set the following Registry key to 0.

```
HKLM\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\TLS 1.2\Server:DisabledByDefault
```

To enable using PowerShell enter the following command:

```
New-Item
'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\
TLS 1.2\Server' -Force | Out-Null

New-ItemProperty -path
'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\
TLS 1.2\Server' -name 'Enabled' -value '1' -PropertyType 'DWord' -Force |
Out-Null

New-ItemProperty -path
'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\
TLS 1.2\Server' -name 'DisabledByDefault' -value '0' -PropertyType 'DWord' -
Force | Out-Null
```

References:

1. <http://msdn.microsoft.com/en-us/library/aa374757%28v=vs.85%29.aspx>
2. https://www.owasp.org/index.php/Testing_for_SSL-TLS_%28OWASP-CM-001%29
3. <http://technet.microsoft.com/en-us/library/dn786419.aspx>
4. <http://technet.microsoft.com/en-us/library/dn786433.aspx>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.10 Encrypt Sensitive Data in Transit Encrypt sensitive data in transit. Example implementations can include: Transport Layer Security (TLS) and Open Secure Shell (OpenSSH).			
v7	14.4 Encrypt All Sensitive Information in Transit Encrypt all sensitive information in transit.			

7.7 (L1) Ensure NULL Cipher Suites is Disabled (Automated)

Profile Applicability:

- Level 1 - IIS 10

Description:

The NULL cipher does not provide data confidentiality or integrity, therefore it is recommended that the NULL cipher be disabled.

Rationale:

By disabling the NULL cipher, there is a better chance of maintaining data confidentiality and integrity.

Impact:

The NULL cipher suite will not be available.

Audit:

Perform the following to verify NULL cipher is disabled:

1. Ensure the following Registry key is set to 0.

```
HKLM\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Ciphers\NULL:Enabled
```

To verify using PowerShell enter the following command:

```
Get-ItemProperty -path  
'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Ciphers\NU  
LL' -name 'Enabled'
```

Remediation:

Perform the following to disable NULL cipher:

1. Set the following Registry key to 0.

```
HKLM\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Ciphers\NULL:Enabled
```

To disable using PowerShell enter the following command:

```
New-Item  
'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Ciphers\NULL' -Force | Out-Null  
  
New-ItemProperty -path  
'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Ciphers\NULL' -name 'Enabled' -value '0' -PropertyType 'DWord' -Force | Out-Null
```

References:

1. [https://www.owasp.org/index.php/Testing_for_SSL-TLS %28OWASP-CM-001%29](https://www.owasp.org/index.php/Testing_for_SSL-TLS_%28OWASP-CM-001%29)
2. <http://technet.microsoft.com/en-us/library/dn786419.aspx>
3. <http://technet.microsoft.com/en-us/library/dn786433.aspx>
4. <http://msdn.microsoft.com/en-us/library/aa374757%28v=vs.85%29.aspx>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.10 <u>Encrypt Sensitive Data in Transit</u> Encrypt sensitive data in transit. Example implementations can include: Transport Layer Security (TLS) and Open Secure Shell (OpenSSH).			
v7	14.4 <u>Encrypt All Sensitive Information in Transit</u> Encrypt all sensitive information in transit.			

7.8 (L1) Ensure DES Cipher Suites is Disabled (Automated)

Profile Applicability:

- Level 1 - IIS 10

Description:

The DES Cipher Suite is considered a weak symmetric-key cipher, therefore it is recommended that it be disabled.

Rationale:

By disabling DES, there is a better chance of maintaining data confidentiality and integrity.

Impact:

The DES Cipher Suite will not be available.

Audit:

Perform the following to verify DES 56/56 cipher is disabled:

1. Ensure the following Registry key is set to 0.

```
HKLM\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Ciphers\DES  
56/56:Enabled
```

To verify using PowerShell enter the following command:

```
Get-ItemProperty -path  
'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Ciphers\DE  
S 56/56' -name 'Enabled'
```


Remediation:

Perform the following to disable DES 56/56 cipher:

1. Set the following Registry key to 0.

```
HKLM\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Ciphers\DES 56/56:Enabled
```

To disable using PowerShell enter the following command:

```
(Get-Item 'HKLM:\').OpenSubKey('SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Ciphers', $true).CreateSubKey('DES 56/56')

New-ItemProperty -path 'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Ciphers\DES 56/56' -name 'Enabled' -value '0' -PropertyType 'DWord' -Force | Out-Null
```

References:

1. [https://www.owasp.org/index.php/Testing_for_SSL-TLS %28OWASP-CM-001%29](https://www.owasp.org/index.php/Testing_for_SSL-TLS_%28OWASP-CM-001%29)
2. <http://technet.microsoft.com/en-us/library/dn786433.aspx>
3. <http://technet.microsoft.com/en-us/library/dn786419.aspx>
4. <http://msdn.microsoft.com/en-us/library/aa374757%28v=vs.85%29.aspx>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.10 <u>Encrypt Sensitive Data in Transit</u> Encrypt sensitive data in transit. Example implementations can include: Transport Layer Security (TLS) and Open Secure Shell (OpenSSH).			
v7	14.4 <u>Encrypt All Sensitive Information in Transit</u> Encrypt all sensitive information in transit.			

7.9 (L1) Ensure RC4 Cipher Suites is Disabled (Automated)

Profile Applicability:

- Level 1 - IIS 10

Description:

The RC4 Cipher Suites are considered insecure, therefore should be disabled.

Note: RC4 cipher enabled by default on Server 2012 and 2012 R2 is RC4 128/128.

Rationale:

The use of RC4 may increase an adversaries ability to read sensitive information sent over SSL/TLS.

Impact:

The RC4 Cipher Suites will not be available. The use of RC4 in TLS and SSL could allow an attacker to perform man-in-the-middle attacks and recover plaintext from encrypted sessions.

Audit:

Perform the following to verify RC4 40/128, RC4 56/128, RC4 64/128, RC4 128/128 ciphers have been disabled.

1. Ensure the following Registry keys are set to 0.

```
HKLM\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Ciphers\RC4
40/128:Enabled
HKLM\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Ciphers\RC4
56/128:Enabled
HKLM\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Ciphers\RC4
64/128:Enabled
HKLM\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Ciphers\RC4
128/128:Enabled
```

To verify using PowerShell enter the following commands:

```
Get-ItemProperty -path
'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Ciphers\RC
4 40/128' -name 'Enabled'
Get-ItemProperty -path
'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Ciphers\RC
4 56/128' -name 'Enabled'
Get-ItemProperty -path
'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Ciphers\RC
4 64/128' -name 'Enabled'
Get-ItemProperty -path
'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Ciphers\RC
4 128/128' -name 'Enabled'
```

Remediation:

Perform the following to disable RC4 40/128, RC4 56/128, RC4 64/128, RC4 128/128 ciphers:

1. Set the following Registry keys to 0.

```
HKLM\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Ciphers\RC4
40/128:Enabled
HKLM\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Ciphers\RC4
56/128:Enabled
HKLM\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Ciphers\RC4
64/128:Enabled
HKLM\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Ciphers\RC4
128/128:Enabled
```

To disable using PowerShell enter the following commands:

```
(Get-Item
'HKLM:\').OpenSubKey('SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHA
NNEL\Ciphers', $true).CreateSubKey('RC4 40/128')

New-ItemProperty -path
'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Ciphers\RC
4 40/128' -name 'Enabled' -value '0' -PropertyType 'DWord' -Force | Out-Null

(Get-Item
'HKLM:\').OpenSubKey('SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHA
NNEL\Ciphers', $true).CreateSubKey('RC4 56/128')

New-ItemProperty -path
'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Ciphers\RC
4 56/128' -name 'Enabled' -value '0' -PropertyType 'DWord' -Force | Out-Null

(Get-Item
'HKLM:\').OpenSubKey('SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHA
NNEL\Ciphers', $true).CreateSubKey('RC4 64/128')

New-ItemProperty -path
'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Ciphers\RC
4 64/128' -name 'Enabled' -value '0' -PropertyType 'DWord' -Force | Out-Null

(Get-Item
'HKLM:\').OpenSubKey('SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHA
NNEL\Ciphers', $true).CreateSubKey('RC4 128/128')

New-ItemProperty -path
'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Ciphers\RC
4 128/128' -name 'Enabled' -value '0' -PropertyType 'DWord' -Force | Out-Null
```

References:

1. <http://msdn.microsoft.com/en-us/library/aa374757%28v=vs.85%29.aspx>
2. <http://technet.microsoft.com/en-us/library/dn786433.aspx>
3. <http://technet.microsoft.com/en-us/library/dn786419.aspx>
4. https://www.owasp.org/index.php/Testing_for_SSL-TLS_%28OWASP-CM-001%29

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.10 <u>Encrypt Sensitive Data in Transit</u> Encrypt sensitive data in transit. Example implementations can include: Transport Layer Security (TLS) and Open Secure Shell (OpenSSH).			
v7	14.4 <u>Encrypt All Sensitive Information in Transit</u> Encrypt all sensitive information in transit.			

7.10 (L1) Ensure AES 128/128 Cipher Suite is Disabled (Automated)

Profile Applicability:

- Level 1 - IIS 10

Description:

The AES 128/128 Cipher Suite is not considered secure and therefore should be disabled, if possible.

Rationale:

This item is Scored for the following reasons and should be disabled:

- Enabling AES 256/256 is recommended.
- This cipher does not suffer from known practical attacks.

Impact:

Warning: Enabling AES 128/128 may be required for client compatibility.

Audit:

Perform the following to verify AES 128/128 cipher is disabled:

1. Ensure the following Registry key is set to 0.

```
HKLM\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Ciphers\AES  
128/128:Enabled
```

To verify using PowerShell enter the following command:

```
Get-ItemProperty -path  
'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Ciphers\AE  
S 128/128' -name 'Enabled'
```

Remediation:

Perform the following to disable AES 128/128 cipher:

1. Set the following Registry key to 0.

```
HKLM\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Ciphers\AES  
128/128:Enabled
```

To disable using PowerShell enter the following command:

```
(Get-Item  
'HKLM:\').OpenSubKey('SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHAN  
NEL\Ciphers', $true).CreateSubKey('AES 128/128')  
  
New-ItemProperty -path  
'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Ciphers\AE  
S 128/128' -name 'Enabled' -value '0' -PropertyType 'DWord' -Force | Out-Null
```

References:

1. <http://technet.microsoft.com/en-us/library/dn786419.aspx>
2. <http://msdn.microsoft.com/en-us/library/aa374757%28v=vs.85%29.aspx>
3. [https://www.owasp.org/index.php/Testing_for_SSL-TLS %28OWASP-CM-001%29](https://www.owasp.org/index.php/Testing_for_SSL-TLS_%28OWASP-CM-001%29)
4. <http://technet.microsoft.com/en-us/library/dn786433.aspx>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.10 <u>Encrypt Sensitive Data in Transit</u> Encrypt sensitive data in transit. Example implementations can include: Transport Layer Security (TLS) and Open Secure Shell (OpenSSH).			
v7	14.4 <u>Encrypt All Sensitive Information in Transit</u> Encrypt all sensitive information in transit.			

7.11 (L1) Ensure AES 256/256 Cipher Suite is Enabled (Automated)

Profile Applicability:

- Level 1 - IIS 10

Description:

AES 256/256 is the most recent and mature cipher suite for protecting the confidentiality and integrity of HTTP traffic. Enabling AES 256/256 is recommended.

Note: AES 256/256 is enabled by default starting with Server 2012 and 2012 R2.

Rationale:

Enabling this cipher will help ensure the confidentiality and integrity of data in transit.

Impact:

N/A

Audit:

Perform the following to verify AES 256/256 cipher is enabled:

1. Ensure the following Registry key is set to 1.

```
HKLM\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Ciphers\AES  
256/256:Enabled
```

To verify using PowerShell enter the following command:

```
Get-ItemProperty -path  
'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Ciphers\AE  
S 256/256' -name 'Enabled'
```


Remediation:

Perform the following to enable AES 256/256 cipher:

1. Set the following Registry key to 1.

```
HKLM\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Ciphers\AES  
256/256:Enabled
```

To enable using PowerShell enter the following command:

```
(Get-Item  
'HKLM:\').OpenSubKey('SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHAN  
NEL\Ciphers', $true).CreateSubKey('AES 256/256')  
  
New-ItemProperty -path  
'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Ciphers\AE  
S 256/256' -name 'Enabled' -value '1' -PropertyType 'DWord' -Force | Out-Null
```

References:

1. <http://technet.microsoft.com/en-us/library/dn786419.aspx>
2. <http://msdn.microsoft.com/en-us/library/aa374757%28v=vs.85%29.aspx>
3. [https://www.owasp.org/index.php/Testing_for_SSL-TLS %28OWASP-CM-001%29](https://www.owasp.org/index.php/Testing_for_SSL-TLS_%28OWASP-CM-001%29)
4. <http://technet.microsoft.com/en-us/library/dn786433.aspx>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.10 <u>Encrypt Sensitive Data in Transit</u> Encrypt sensitive data in transit. Example implementations can include: Transport Layer Security (TLS) and Open Secure Shell (OpenSSH).			
v7	14.4 <u>Encrypt All Sensitive Information in Transit</u> Encrypt all sensitive information in transit.			

7.12 (L2) Ensure TLS Cipher Suite ordering is Configured (Automated)

Profile Applicability:

- Level 2 - IIS 10

Description:

Cipher suites are a named combination of authentication, encryption, message authentication code, and key exchange algorithms used for the security settings of a network connection using TLS protocol. Clients send a cipher list and a list of ciphers that it supports in order of preference to a server. The server then replies with the cipher suite that it selects from the client cipher suite list.

Rationale:

Cipher suites should be ordered from strongest to weakest in order to ensure that the more secure configuration is used for encryption between the server and client.

TLS_ECDHE_ECDSA_WITH_AES_256_GCM_SHA384
TLS_ECDHE_ECDSA_WITH_AES_128_GCM_SHA256
TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384
TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256
TLS_ECDHE_ECDSA_WITH_AES_256_CBC_SHA384
TLS_ECDHE_ECDSA_WITH_AES_128_CBC_SHA256
TLS_ECDHE_RSA_WITH_AES_256_CBC_SHA384
TLS_ECDHE_RSA_WITH_AES_128_CBC_SHA256

Avoid cipher suits that do not provide Perfect Forward Secrecy or use weak hashing function, use them only if you need to support backwards compatibility and in the bottom of the list and you will have to create exceptions for the items that cause this to become out of compliance:

TLS_ECDHE_ECDSA_WITH_AES_256_CBC_SHA (uses SHA-1)
TLS_ECDHE_RSA_WITH_AES_256_CBC_SHA (uses SHA-1)
TLS_ECDHE_ECDSA_WITH_AES_128_CBC_SHA (uses SHA-1)
TLS_ECDHE_RSA_WITH_AES_128_CBC_SHA (uses SHA-1)
TLS_RSA_WITH_AES_256_GCM_SHA384 (lack of Perfect Forward Secrecy)
TLS_RSA_WITH_AES_128_GCM_SHA256 (lack of Perfect Forward Secrecy)
TLS_RSA_WITH_AES_256_CBC_SHA256 (lack of Perfect Forward Secrecy)
TLS_RSA_WITH_AES_128_CBC_SHA256 (lack of Perfect Forward Secrecy)
TLS_RSA_WITH_AES_256_CBC_SHA (uses SHA-1, lack of Perfect Forward Secrecy)
TLS_RSA_WITH_AES_128_CBC_SHA (uses SHA-1, lack of Perfect Forward Secrecy)

Note: HTTP/2 compatibility: first 4 ciphers (in bold) in the top part list are compatible with HTTP/2

Impact:

Cipher ordering is important to ensure that the most secure ciphers are listed first and will be applied over weaker ciphers when possible.

Audit:

Perform the following to verify the TLS cipher suite order is configured properly:

1. Ensure the following Registry key is set to

TLS_AES_256_GCM_SHA384,TLS_AES_128_GCM_SHA256,TLS_ECDHE_ECDSA_WITH_AES_256_GCM_SHA384,TLS_ECDHE_ECDSA_WITH_AES_128_GCM_SHA256,TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384,TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256,TLS_ECDHE_ECDSA_WITH_AES_256_CBC_SHA384,TLS_ECDHE_ECDSA_WITH_AES_128_CBC_SHA256,TLS_ECDHE_RSA_WITH_AES_256_CBC_SHA384,TLS_ECDHE_RSA_WITH_AES_128_CBC_SHA256.

```
HKLM\SOFTWARE\Policies\Microsoft\Cryptography\Configuration\SSL\00010002:Functions
```

To verify using PowerShell enter the following command:

```
Get-ItemProperty -path  
'HKLM:\SOFTWARE\Policies\Microsoft\Cryptography\Configuration\SSL\00010002' -  
name 'Functions'
```

TLS_AES_256_GCM_SHA384 TLS_AES_128_GCM_SHA256

Remediation:

Perform the following to configure TLS cipher suite order:

1. Set the following Registry key to TLS_AES_256_GCM_SHA384, TLS_AES_128_GCM_SHA256, TLS_ECDHE_ECDSA_WITH_AES_256_GCM_SHA384, TLS_ECDHE_ECDSA_WITH_AES_128_GCM_SHA256, TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384, TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256, TLS_ECDHE_ECDSA_WITH_AES_256_CBC_SHA384, TLS_ECDHE_ECDSA_WITH_AES_128_CBC_SHA256, TLS_ECDHE_RSA_WITH_AES_256_CBC_SHA384, TLS_ECDHE_RSA_WITH_AES_128_CBC_SHA256.

```
HKLM\SOFTWARE\Policies\Microsoft\Cryptography\Configuration\SSL\00010002:Functions
```

To configure TLS cipher suite order using PowerShell enter the following command:

```
New-Item  
'HKLM:\SOFTWARE\Policies\Microsoft\Cryptography\Configuration\SSL\00010002' -  
Force | Out-Null  
  
New-ItemProperty -path  
'HKLM:\SOFTWARE\Policies\Microsoft\Cryptography\Configuration\SSL\00010002' -  
name 'Functions' -value  
'TLS_AES_256_GCM_SHA384,TLS_AES_128_GCM_SHA256,TLS_ECDHE_ECDSA_WITH_AES_256_G  
CM_SHA384,TLS_ECDHE_ECDSA_WITH_AES_128_GCM_SHA256,TLS_ECDHE_RSA_WITH_AES_256_  
GCM_SHA384,TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256,TLS_ECDHE_ECDSA_WITH_AES_256_  
CBC_SHA384,TLS_ECDHE_ECDSA_WITH_AES_128_CBC_SHA256,TLS_ECDHE_RSA_WITH_AES_25  
6_CBC_SHA384,TLS_ECDHE_RSA_WITH_AES_128_CBC_SHA256' -PropertyType  
'MultiString' -Force | Out-Null
```

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.10 <u>Encrypt Sensitive Data in Transit</u> Encrypt sensitive data in transit. Example implementations can include: Transport Layer Security (TLS) and Open Secure Shell (OpenSSH).			
v7	14.4 <u>Encrypt All Sensitive Information in Transit</u> Encrypt all sensitive information in transit.			

Appendix: Summary Table

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
1	Basic Configurations		
1.1	(L1) Ensure 'Web content' is on non-system partition (Manual)	☐	☐
1.2	(L1) Ensure 'Host headers' are on all sites (Automated)	☐	☐
1.3	(L1) Ensure 'Directory browsing' is set to Disabled (Automated)	☐	☐
1.4	(L1) Ensure 'application pool identity' is configured for all application pools (Automated)	☐	☐
1.5	(L1) Ensure 'unique application pools' is set for sites (Automated)	☐	☐
1.6	(L1) Ensure 'application pool identity' is configured for anonymous user identity (Automated)	☐	☐
1.7	(L1) Ensure 'WebDav' feature is disabled (Automated)	☐	☐
2	Configure Authentication and Authorization		
2.1	(L1) Ensure 'global authorization rule' is set to restrict access (Manual)	☐	☐
2.2	(L1) Ensure access to sensitive site features is restricted to authenticated principals only (Manual)	☐	☐
2.3	(L1) Ensure 'forms authentication' require SSL (Automated)	☐	☐
2.4	(L2) Ensure 'forms authentication' is set to use cookies (Automated)	☐	☐
2.5	(L1) Ensure 'cookie protection mode' is configured for forms authentication (Automated)	☐	☐

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
2.6	(L1) Ensure transport layer security for 'basic authentication' is configured (Automated)	☐	☐
2.7	(L1) Ensure 'passwordFormat' is not set to clear (Automated)	☐	☐
2.8	(L2) Ensure 'credentials' are not stored in configuration files (Automated)	☐	☐
3	ASP.NET Configuration Recommendations		
3.1	(L1) Ensure 'deployment method retail' is set (Manual)	☐	☐
3.2	(L2) Ensure 'debug' is turned off (Automated)	☐	☐
3.3	(L2) Ensure custom error messages are not off (Automated)	☐	☐
3.4	(L1) Ensure IIS HTTP detailed errors are hidden from displaying remotely (Automated)	☐	☐
3.5	(L2) Ensure ASP.NET stack tracing is not enabled (Automated)	☐	☐
3.6	(L2) Ensure 'httpcookie' mode is configured for session state (Automated)	☐	☐
3.7	(L1) Ensure 'cookies' are set with HttpOnly attribute (Automated)	☐	☐
3.8	(L2) Ensure 'MachineKey validation method - .Net 3.5' is configured (Automated)	☐	☐
3.9	(L1) Ensure 'MachineKey validation method - .Net 4.5' is configured (Automated)	☐	☐
3.10	(L1) Ensure global .NET trust level is configured (Automated)	☐	☐
3.11	(L2) Ensure X-Powered-By Header is removed (Manual)	☐	☐
3.12	(L2) Ensure Server Header is removed (Manual)	☐	☐

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
4	Request Filtering and Other Restriction Modules		
4.1	(L2) Ensure 'maxAllowedContentLength' is configured (Manual)	☐	☐
4.2	(L2) Ensure 'maxURL request filter' is configured (Automated)	☐	☐
4.3	(L2) Ensure 'MaxQueryString request filter' is configured (Automated)	☐	☐
4.4	(L2) Ensure non-ASCII characters in URLs are not allowed (Automated)	☐	☐
4.5	(L1) Ensure Double-Encoded requests will be rejected (Automated)	☐	☐
4.6	(L1) Ensure 'HTTP Trace Method' is disabled (Manual)	☐	☐
4.7	(L1) Ensure Unlisted File Extensions are not allowed (Automated)	☐	☐
4.8	(L1) Ensure Handler is not granted Write and Script/Execute (Manual)	☐	☐
4.9	(L1) Ensure 'notListedIsapisAllowed' is set to false (Automated)	☐	☐
4.10	(L1) Ensure 'notListedCgisAllowed' is set to false (Automated)	☐	☐
4.11	(L1) Ensure 'Dynamic IP Address Restrictions' is enabled (Manual)	☐	☐
5	IIS Logging Recommendations		
5.1	(L1) Ensure Default IIS web log location is moved (Automated)	☐	☐
5.2	(L1) Ensure Advanced IIS logging is enabled (Automated)	☐	☐

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
5.3	(L1) Ensure 'ETW Logging' is enabled (Manual)	☐	☐
6	FTP Requests		
6.1	(L1) Ensure FTP requests are encrypted (Manual)	☐	☐
6.2	(L1) Ensure FTP Logon attempt restrictions is enabled (Manual)	☐	☐
7	Transport Encryption		
7.1	(L2) Ensure HSTS Header is set (Manual)	☐	☐
7.2	(L1) Ensure SSLv2 is Disabled (Automated)	☐	☐
7.3	(L1) Ensure SSLv3 is Disabled (Automated)	☐	☐
7.4	(L1) Ensure TLS 1.0 is Disabled (Automated)	☐	☐
7.5	(L1) Ensure TLS 1.1 is Disabled (Automated)	☐	☐
7.6	(L1) Ensure TLS 1.2 is Enabled (Automated)	☐	☐
7.7	(L1) Ensure NULL Cipher Suites is Disabled (Automated)	☐	☐
7.8	(L1) Ensure DES Cipher Suites is Disabled (Automated)	☐	☐
7.9	(L1) Ensure RC4 Cipher Suites is Disabled (Automated)	☐	☐
7.10	(L1) Ensure AES 128/128 Cipher Suite is Disabled (Automated)	☐	☐
7.11	(L1) Ensure AES 256/256 Cipher Suite is Enabled (Automated)	☐	☐
7.12	(L2) Ensure TLS Cipher Suite ordering is Configured (Automated)	☐	☐

Appendix: CIS Controls v7 IG 1 Mapped Recommendations

Recommendation		Set Correctly	
		Yes	No
1.5	(L1) Ensure 'unique application pools' is set for sites	☐	☐
1.6	(L1) Ensure 'application pool identity' is configured for anonymous user identity	☐	☐
2.2	(L1) Ensure access to sensitive site features is restricted to authenticated principals only	☐	☐
3.10	(L1) Ensure global .NET trust level is configured	☐	☐
5.2	(L1) Ensure Advanced IIS logging is enabled	☐	☐

Appendix: CIS Controls v7 IG 2 Mapped Recommendations

Recommendation		Set Correctly	
		Yes	No
1.5	(L1) Ensure 'unique application pools' is set for sites	☐	☐
1.6	(L1) Ensure 'application pool identity' is configured for anonymous user identity	☐	☐
1.7	(L1) Ensure 'WebDav' feature is disabled	☐	☐
2.2	(L1) Ensure access to sensitive site features is restricted to authenticated principals only	☐	☐
2.3	(L1) Ensure 'forms authentication' require SSL	☐	☐
2.6	(L1) Ensure transport layer security for 'basic authentication' is configured	☐	☐
2.7	(L1) Ensure 'passwordFormat' is not set to clear	☐	☐
2.8	(L2) Ensure 'credentials' are not stored in configuration files	☐	☐
3.8	(L2) Ensure 'MachineKey validation method - .Net 3.5' is configured	☐	☐
3.9	(L1) Ensure 'MachineKey validation method - .Net 4.5' is configured	☐	☐
3.10	(L1) Ensure global .NET trust level is configured	☐	☐
5.1	(L1) Ensure Default IIS web log location is moved	☐	☐
5.2	(L1) Ensure Advanced IIS logging is enabled	☐	☐
5.3	(L1) Ensure 'ETW Logging' is enabled	☐	☐
6.1	(L1) Ensure FTP requests are encrypted	☐	☐
6.2	(L1) Ensure FTP Logon attempt restrictions is enabled	☐	☐
7.2	(L1) Ensure SSLv2 is Disabled	☐	☐
7.3	(L1) Ensure SSLv3 is Disabled	☐	☐
7.4	(L1) Ensure TLS 1.0 is Disabled	☐	☐
7.5	(L1) Ensure TLS 1.1 is Disabled	☐	☐
7.6	(L1) Ensure TLS 1.2 is Enabled	☐	☐
7.7	(L1) Ensure NULL Cipher Suites is Disabled	☐	☐
7.8	(L1) Ensure DES Cipher Suites is Disabled	☐	☐

Recommendation		Set Correctly	
		Yes	No
7.9	(L1) Ensure RC4 Cipher Suites is Disabled	☐	☐
7.10	(L1) Ensure AES 128/128 Cipher Suite is Disabled	☐	☐
7.11	(L1) Ensure AES 256/256 Cipher Suite is Enabled	☐	☐
7.12	(L2) Ensure TLS Cipher Suite ordering is Configured	☐	☐

Appendix: CIS Controls v7 IG 3 Mapped Recommendations

Recommendation		Set Correctly	
		Yes	No
1.5	(L1) Ensure 'unique application pools' is set for sites	☐	☐
1.6	(L1) Ensure 'application pool identity' is configured for anonymous user identity	☐	☐
1.7	(L1) Ensure 'WebDav' feature is disabled	☐	☐
2.2	(L1) Ensure access to sensitive site features is restricted to authenticated principals only	☐	☐
2.3	(L1) Ensure 'forms authentication' require SSL	☐	☐
2.6	(L1) Ensure transport layer security for 'basic authentication' is configured	☐	☐
2.7	(L1) Ensure 'passwordFormat' is not set to clear	☐	☐
2.8	(L2) Ensure 'credentials' are not stored in configuration files	☐	☐
3.8	(L2) Ensure 'MachineKey validation method - .Net 3.5' is configured	☐	☐
3.9	(L1) Ensure 'MachineKey validation method - .Net 4.5' is configured	☐	☐
3.10	(L1) Ensure global .NET trust level is configured	☐	☐
4.11	(L1) Ensure 'Dynamic IP Address Restrictions' is enabled	☐	☐
5.1	(L1) Ensure Default IIS web log location is moved	☐	☐
5.2	(L1) Ensure Advanced IIS logging is enabled	☐	☐
5.3	(L1) Ensure 'ETW Logging' is enabled	☐	☐
6.1	(L1) Ensure FTP requests are encrypted	☐	☐
6.2	(L1) Ensure FTP Logon attempt restrictions is enabled	☐	☐
7.2	(L1) Ensure SSLv2 is Disabled	☐	☐
7.3	(L1) Ensure SSLv3 is Disabled	☐	☐
7.4	(L1) Ensure TLS 1.0 is Disabled	☐	☐
7.5	(L1) Ensure TLS 1.1 is Disabled	☐	☐
7.6	(L1) Ensure TLS 1.2 is Enabled	☐	☐
7.7	(L1) Ensure NULL Cipher Suites is Disabled	☐	☐

Recommendation		Set Correctly	
		Yes	No
7.8	(L1) Ensure DES Cipher Suites is Disabled	☐	☐
7.9	(L1) Ensure RC4 Cipher Suites is Disabled	☐	☐
7.10	(L1) Ensure AES 128/128 Cipher Suite is Disabled	☐	☐
7.11	(L1) Ensure AES 256/256 Cipher Suite is Enabled	☐	☐
7.12	(L2) Ensure TLS Cipher Suite ordering is Configured	☐	☐

Appendix: CIS Controls v7 Unmapped Recommendations

Recommendation		Set Correctly	
		Yes	No
3.11	(L2) Ensure X-Powered-By Header is removed	☐	☐
3.12	(L2) Ensure Server Header is removed	☐	☐

Appendix: CIS Controls v8 IG 1 Mapped Recommendations

Recommendation		Set Correctly	
		Yes	No
2.1	(L1) Ensure 'global authorization rule' is set to restrict access	☐	☐
3.10	(L1) Ensure global .NET trust level is configured	☐	☐
5.1	(L1) Ensure Default IIS web log location is moved	☐	☐

Appendix: CIS Controls v8 IG 2 Mapped Recommendations

Recommendation		Set Correctly	
		Yes	No
1.3	(L1) Ensure 'Directory browsing' is set to Disabled	☐	☐
1.7	(L1) Ensure 'WebDav' feature is disabled	☐	☐
2.1	(L1) Ensure 'global authorization rule' is set to restrict access	☐	☐
2.3	(L1) Ensure 'forms authentication' require SSL	☐	☐
2.5	(L1) Ensure 'cookie protection mode' is configured for forms authentication	☐	☐
2.6	(L1) Ensure transport layer security for 'basic authentication' is configured	☐	☐
2.7	(L1) Ensure 'passwordFormat' is not set to clear	☐	☐
3.8	(L2) Ensure 'MachineKey validation method - .Net 3.5' is configured	☐	☐
3.9	(L1) Ensure 'MachineKey validation method - .Net 4.5' is configured	☐	☐
3.10	(L1) Ensure global .NET trust level is configured	☐	☐
3.11	(L2) Ensure X-Powered-By Header is removed	☐	☐
3.12	(L2) Ensure Server Header is removed	☐	☐
4.5	(L1) Ensure Double-Encoded requests will be rejected	☐	☐
5.1	(L1) Ensure Default IIS web log location is moved	☐	☐
5.2	(L1) Ensure Advanced IIS logging is enabled	☐	☐
5.3	(L1) Ensure 'ETW Logging' is enabled	☐	☐
6.1	(L1) Ensure FTP requests are encrypted	☐	☐
6.2	(L1) Ensure FTP Logon attempt restrictions is enabled	☐	☐
7.1	(L2) Ensure HSTS Header is set	☐	☐
7.3	(L1) Ensure SSLv3 is Disabled	☐	☐
7.4	(L1) Ensure TLS 1.0 is Disabled	☐	☐
7.6	(L1) Ensure TLS 1.2 is Enabled	☐	☐
7.7	(L1) Ensure NULL Cipher Suites is Disabled	☐	☐

Recommendation		Set Correctly	
		Yes	No
7.8	(L1) Ensure DES Cipher Suites is Disabled	☐	☐
7.9	(L1) Ensure RC4 Cipher Suites is Disabled	☐	☐
7.10	(L1) Ensure AES 128/128 Cipher Suite is Disabled	☐	☐
7.11	(L1) Ensure AES 256/256 Cipher Suite is Enabled	☐	☐
7.12	(L2) Ensure TLS Cipher Suite ordering is Configured	☐	☐

Appendix: CIS Controls v8 IG 3 Mapped Recommendations

Recommendation		Set Correctly	
		Yes	No
1.3	(L1) Ensure 'Directory browsing' is set to Disabled	☐	☐
1.4	(L1) Ensure 'application pool identity' is configured for all application pools	☐	☐
1.7	(L1) Ensure 'WebDav' feature is disabled	☐	☐
2.1	(L1) Ensure 'global authorization rule' is set to restrict access	☐	☐
2.3	(L1) Ensure 'forms authentication' require SSL	☐	☐
2.5	(L1) Ensure 'cookie protection mode' is configured for forms authentication	☐	☐
2.6	(L1) Ensure transport layer security for 'basic authentication' is configured	☐	☐
2.7	(L1) Ensure 'passwordFormat' is not set to clear	☐	☐
3.8	(L2) Ensure 'MachineKey validation method - .Net 3.5' is configured	☐	☐
3.9	(L1) Ensure 'MachineKey validation method - .Net 4.5' is configured	☐	☐
3.10	(L1) Ensure global .NET trust level is configured	☐	☐
3.11	(L2) Ensure X-Powered-By Header is removed	☐	☐
3.12	(L2) Ensure Server Header is removed	☐	☐
4.5	(L1) Ensure Double-Encoded requests will be rejected	☐	☐
4.8	(L1) Ensure Handler is not granted Write and Script/Execute	☐	☐
4.11	(L1) Ensure 'Dynamic IP Address Restrictions' is enabled	☐	☐
5.1	(L1) Ensure Default IIS web log location is moved	☐	☐
5.2	(L1) Ensure Advanced IIS logging is enabled	☐	☐
5.3	(L1) Ensure 'ETW Logging' is enabled	☐	☐
6.1	(L1) Ensure FTP requests are encrypted	☐	☐
6.2	(L1) Ensure FTP Logon attempt restrictions is enabled	☐	☐
7.1	(L2) Ensure HSTS Header is set	☐	☐

Recommendation		Set Correctly	
		Yes	No
7.2	(L1) Ensure SSLv2 is Disabled	☐	☐
7.3	(L1) Ensure SSLv3 is Disabled	☐	☐
7.4	(L1) Ensure TLS 1.0 is Disabled	☐	☐
7.5	(L1) Ensure TLS 1.1 is Disabled	☐	☐
7.6	(L1) Ensure TLS 1.2 is Enabled	☐	☐
7.7	(L1) Ensure NULL Cipher Suites is Disabled	☐	☐
7.8	(L1) Ensure DES Cipher Suites is Disabled	☐	☐
7.9	(L1) Ensure RC4 Cipher Suites is Disabled	☐	☐
7.10	(L1) Ensure AES 128/128 Cipher Suite is Disabled	☐	☐
7.11	(L1) Ensure AES 256/256 Cipher Suite is Enabled	☐	☐
7.12	(L2) Ensure TLS Cipher Suite ordering is Configured	☐	☐

Appendix: CIS Controls v8 Unmapped Recommendations

Recommendation		Set Correctly	
		Yes	No
1.1	(L1) Ensure 'Web content' is on non-system partition	☐	☐
1.2	(L1) Ensure 'Host headers' are on all sites	☐	☐
1.5	(L1) Ensure 'unique application pools' is set for sites	☐	☐
1.6	(L1) Ensure 'application pool identity' is configured for anonymous user identity	☐	☐
2.2	(L1) Ensure access to sensitive site features is restricted to authenticated principals only	☐	☐
2.4	(L2) Ensure 'forms authentication' is set to use cookies	☐	☐
2.8	(L2) Ensure 'credentials' are not stored in configuration files	☐	☐
3.1	(L1) Ensure 'deployment method retail' is set	☐	☐
3.2	(L2) Ensure 'debug' is turned off	☐	☐
3.3	(L2) Ensure custom error messages are not off	☐	☐
3.4	(L1) Ensure IIS HTTP detailed errors are hidden from displaying remotely	☐	☐
3.5	(L2) Ensure ASP.NET stack tracing is not enabled	☐	☐
3.6	(L2) Ensure 'httpcookie' mode is configured for session state	☐	☐
3.7	(L1) Ensure 'cookies' are set with HttpOnly attribute	☐	☐
4.1	(L2) Ensure 'maxAllowedContentLength' is configured	☐	☐
4.2	(L2) Ensure 'maxURL request filter' is configured	☐	☐
4.3	(L2) Ensure 'MaxQueryString request filter' is configured	☐	☐
4.4	(L2) Ensure non-ASCII characters in URLs are not allowed	☐	☐
4.6	(L1) Ensure 'HTTP Trace Method' is disabled	☐	☐
4.7	(L1) Ensure Unlisted File Extensions are not allowed	☐	☐
4.9	(L1) Ensure 'notListedIsapisAllowed' is set to false	☐	☐
4.10	(L1) Ensure 'notListedCgisAllowed' is set to false	☐	☐

Appendix: Change History

Date	Version	Changes for this version
03/31/2017	1.0.0	Initial Release
12/11/2018	1.1.0	ADD - PS commands for checks to help improve overall benchmark and make future remediation possible
12/11/2018	1.1.0	UPDATE - Ensure AES 128/128 Cipher Suite is Disabled. Ticket#6757
12/11/2018	1.1.0	UPDATE - Ensure TLS Cipher Suite ordering is Configured - Fixed Artifact. Ticket #6751
12/11/2018	1.1.0	UPDATE - Ensure TLS Cipher Suite ordering is Configured - set to Scored. Ticket #6758
12/11/2018	1.1.0	UPDATE - 5.2 Ensure Advanced IIS logging is enabled. Ticket #5075
12/11/2018	1.1.0	REMOVE - IIS 7/IIS 8 clause 7.11 and IIS 10 clause 7.10, they recommend to "Ensure Triple DES Cipher Suite is Disabled (Scored)". Ticket #6909
03/13/2019	1.1.1	Updated PS commands for section 7 which was creating some incorrect subkeys do to a bug in PS. Ticket #8159
11/15/2022	1.2.0	UPDATE - 3.1 (L1) Ensure 'deployment method retail' is set Ticket #9234
11/15/2022	1.2.0	UPDATE - 1.6 (L1) Ensure all sites are configured with no anonymous user account – PowerShell Ticket #9656

Date	Version	Changes for this version
11/15/2022	1.2.0	ADD - 7.9 (L1) Ensure Triple DES Cipher Suites is Disabled Ticket #10329
11/15/2022	1.2.0	CHANGE - 1 Ensure WebDav feature is disable PowerShell Commands Ticket #14284
11/15/2022	1.2.0	ADD - 7 (L2) Ensure TLS Cipher Suite ordering is Configured to include TLS_AES_256_GCM_SHA384 TLS_AES_128_GCM_SHA256 Ticket #16731
07/17/20223	1.2.1	Bug Fix for CIS-CAT Artifacts